

[TÊN CƠ QUAN CHỦ QUẢN]

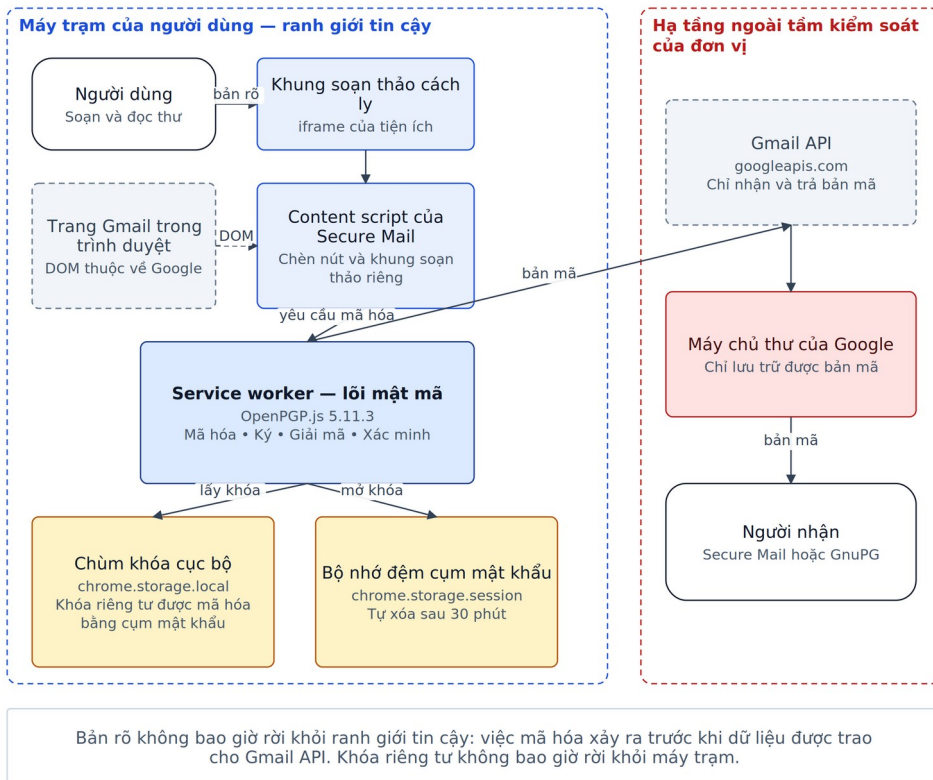
[TÊN ĐƠN VỊ]

BẢN THUYẾT MINH SÁNG KIẾN

SECURE MAIL

Giải pháp mã hóa đầu cuối thư điện tử trên nền Gmail, bản địa hóa tiếng Việt, phục vụ giảng dạy và công tác bảo đảm an toàn thông tin

Kiến trúc tổng thể Secure Mail trên nền Gmail



Tác giả

[Họ và tên]

Chức vụ	Giảng viên
Chuyên ngành	An toàn thông tin trên không gian mạng
Đơn vị	[Tên đơn vị]
Lĩnh vực	Công nghệ thông tin — An toàn thông tin
Phiên bản hồ sơ	1.0

[Địa danh], tháng 9 năm 2026

MỤC LỤC

...

(Mở tệp trong Word và nhấn Ctrl+A rồi F9 để cập nhật mục lục và số trang)

PHẦN MỞ ĐẦU

Cách đọc hồ sơ này

Hồ sơ được viết theo mạch lập luận: vấn đề thực tế → hạn chế của những cách làm hiện có → giải pháp → điểm mới → bằng chứng → hiệu quả. Để thuận tiện cho Hội đồng đối chiếu với các nội dung bắt buộc, bảng dưới đây chỉ rõ nội dung nào nằm ở mục nào.

Bảng 1. Đối chiếu nội dung bắt buộc với các mục của bản thuyết minh

Nội dung theo yêu cầu	Mục trong hồ sơ này
1. Hiện trạng giải pháp đã biết	Mục 3 (3.1 – 3.6), Bảng 2, Bảng 3
2. Mục đích của giải pháp	Mục 4
3a. Nguyên lý của giải pháp	Mục 5
3b. Các nội dung chủ yếu	Mục 6 (6.1 – 6.8), Hình 1 – Hình 7
3c. Kết quả của giải pháp	Mục 7, Bảng 8 – Bảng 11, Phụ lục kỹ thuật
4a. Tính mới và tính sáng tạo	Mục 8 và Mục 9
4b. Khả năng áp dụng	Mục 10
4c. Hiệu quả (kinh tế, kỹ thuật, QP-AN và xã hội)	Mục 11
4d. Mức độ triển khai, phát triển	Mục 13
Phản biện và trả lời	Mục 14

Hồ sơ gồm bốn tài liệu: Đơn đăng ký sáng kiến, Bản thuyết minh (tài liệu này), Phụ lục kỹ thuật (toàn văn kết quả kiểm thử và đo đạc) và Dự kiến hiệu quả khi đưa vào ứng dụng.

Nguyên tắc trình bày số liệu

Mọi con số trong hồ sơ này đều được đo hoặc đếm trực tiếp từ mã nguồn và từ bản phát hành, bằng các kịch bản kèm theo hồ sơ. Mỗi số liệu đều ghi rõ nguồn để Hội đồng có thể chạy lại và tự kiểm chứng. Những thông tin chưa có cơ sở thực tế — số lượng người dùng, hiệu quả kinh tế đã thực hiện, kết quả triển khai diện rộng — được ghi rõ là **dự kiến** hoặc để trống dưới dạng dấu ngoặc vuông [...] để bổ sung sau, chứ không được ước lượng thành con số cụ thể.

PHẦN I. BỐI CẢNH VÀ VẤN ĐỀ ĐẶT RA

1. Bối cảnh công tác

Tác giả là giảng viên trực tiếp giảng dạy môn An toàn thông tin trên không gian mạng. Trong công tác giảng dạy và nghiên cứu, cũng như trong hoạt động thường xuyên của đơn vị, phát sinh hai nhu cầu song song:

Nhu cầu thứ nhất — thực hành mật mã ứng dụng. Mật mã khóa công khai là nội dung trọng tâm của môn học. Người học nắm được lý thuyết (cặp khóa, chữ ký số, hàm băm, hạ tầng khóa công khai) nhưng thường không nối được lý thuyết với thao tác thực tế: sinh khóa, phân phối khóa công khai, đối chiếu dấu vân tay, mã hóa một bức thư thật, phát hiện một chữ ký không hợp lệ. Nguyên nhân không nằm ở năng lực của người học mà nằm ở công cụ: các phần mềm mật mã đầu cuối phổ biến đều chỉ có giao diện tiếng Anh, với hệ thuật ngữ chưa được chuẩn hóa sang tiếng Việt. Người học phải vượt hai rào cản cùng lúc — rào cản khái niệm và rào cản ngôn ngữ — nên phần lớn dừng ở mức "biết có công cụ đó" chứ không đạt tới mức "sử dụng thành thạo".

Nhu cầu thứ hai — bảo vệ thông tin trong trao đổi nghiệp vụ. Công tác của đơn vị phát sinh việc trao đổi tài liệu cần được bảo vệ: đề cương, đề thi chưa công bố, kết quả học tập, dữ liệu cá nhân của người học, bản thảo nghiên cứu, trao đổi nghiệp vụ nội bộ. Thư điện tử là kênh phổ biến và thuận tiện nhất, nhưng thư điện tử thông thường không được thiết kế để mang những nội dung này.

Hai nhu cầu này gặp nhau ở một điểm: **cùng cần một công cụ mã hóa đầu cuối thực dụng, dùng được bằng tiếng Việt, triển khai được trong điều kiện hiện có của đơn vị.** Nếu có công cụ đó, nó vừa là phương tiện bảo vệ thông tin, vừa là học cụ — người học thực hành trên chính công cụ mà cơ quan đang dùng, chứ không phải trên một bài thí nghiệm tách rời thực tế.

2. Vấn đề kỹ thuật

Cần phân biệt rõ hai lớp bảo vệ, vì đây là điểm hay bị đồng nhất:

Mã hóa trên đường truyền (TLS) bảo vệ dữ liệu khi nó đi qua mạng. Gmail, cũng như hầu hết dịch vụ thư điện tử hiện nay, đều dùng TLS. Nhưng TLS kết thúc tại máy chủ của nhà cung cấp. Tại đó, thư được giải mã để lưu trữ, lập chỉ mục, lọc thư

rác. Nói cách khác, **TLS bảo vệ thư trước kẻ nghe lén trên đường, nhưng không bảo vệ thư trước chính nhà cung cấp dịch vụ và trước bất kỳ ai có được quyền truy cập vào hạ tầng của họ.**

Mã hóa đầu cuối (end-to-end) thì khác: bản rõ được mã hóa trên máy người gửi và chỉ được giải mã trên máy người nhận. Nhà cung cấp dịch vụ chỉ nhìn thấy bản mã. Khóa riêng tư không bao giờ rời khỏi máy người dùng.

Với đơn vị, khác biệt này có ý nghĩa cụ thể. Đơn vị không kiểm soát hạ tầng của nhà cung cấp thư điện tử, không kiểm soát chính sách lưu trữ, không kiểm soát vị trí địa lý của trung tâm dữ liệu, không kiểm soát các yêu cầu pháp lý mà nhà cung cấp phải tuân thủ theo luật nước sở tại. Mọi tài liệu nghiệp vụ gửi qua thư điện tử thông thường đều tồn tại ở dạng rõ trên hạ tầng ấy trong toàn bộ thời gian lưu trữ.

Vấn đề kỹ thuật đặt ra là: **làm cho mã hóa đầu cuối trở thành thao tác mà một người dùng bình thường thực hiện được hằng ngày, mà không phải đổi nhà cung cấp thư điện tử, không phải cài đặt hạ tầng mới, không phải học một hệ thuật ngữ ngoại ngữ, và không tạo thêm phụ thuộc mới vào bên thứ ba.**

Bốn điều kiện này ràng buộc nhau. Nói lỏng bất kỳ điều nào cũng làm giải pháp mất giá trị thực tế: bỏ điều kiện thứ nhất thì phải di chuyển toàn bộ hộp thư; bỏ điều kiện thứ hai thì cần đầu tư hạ tầng; bỏ điều kiện thứ ba thì công cụ không dùng được rộng rãi; bỏ điều kiện thứ tư thì chỉ chuyển sự phụ thuộc từ chỗ này sang chỗ khác.

3. Hiện trạng các giải pháp đã biết

Khảo sát các nhóm giải pháp cùng mục đích, đánh giá theo bốn điều kiện nêu trên.

3.1. Nhóm A — Dịch vụ thư điện tử bảo mật (Proton Mail, Tuta)

Đây là các nhà cung cấp thư điện tử đặt bảo mật làm trọng tâm. Thư giữa các tài khoản cùng hệ thống được mã hóa tự động; người dùng không phải thao tác gì thêm.

Ưu điểm. Trải nghiệm liền mạch, người dùng không cần hiểu về khóa. Có ứng dụng di động hoàn chỉnh.

Nhược điểm chưa khắc phục được, xét theo yêu cầu của đơn vị.

- Buộc phải **chuyển toàn bộ hộp thư sang nhà cung cấp mới**, thường đặt ở nước ngoài. Đây không phải quyết định kỹ thuật mà là quyết định tổ chức, kèm chi phí chuyển đổi, đào tạo lại và rủi ro gián đoạn.
- **Khóa riêng tư được lưu trên máy chủ của nhà cung cấp** dưới dạng đã mã hóa bằng mật khẩu tài khoản. Điều này đưa nhà cung cấp vào bên trong ranh giới tin cậy: mô hình an toàn phụ thuộc vào việc mã nguồn phía máy chủ hoạt động đúng như công bố, điều mà người dùng không kiểm chứng được.
- Vẫn là **phụ thuộc vào một nhà cung cấp nước ngoài**, chỉ là đổi tên nhà cung cấp. Bài toán chủ quyền dữ liệu không được giải, chỉ được chuyển chỗ.
- Tuta không dùng chuẩn OpenPGP mà dùng định dạng riêng, nên **không liên thông** được với các công cụ mật mã khác; dữ liệu bị ràng buộc vào nhà cung cấp.
- Không có giao diện tiếng Việt.

3.2. Nhóm B — S/MIME

S/MIME là chuẩn mã hóa và ký thư điện tử dựa trên chứng thư số X.509, được nhiều phần mềm thư điện tử doanh nghiệp hỗ trợ sẵn.

Ưu điểm. Là chuẩn công nghiệp, tích hợp sẵn trong Outlook và nhiều máy khách thư khác. Mô hình tin cậy phân cấp phù hợp với tổ chức có thẩm quyền chứng thực rõ ràng.

Nhược điểm chưa khắc phục được.

- Đòi hỏi **hạ tầng khóa công khai (PKI)**: phải có tổ chức chứng thực, quy trình cấp phát, thu hồi, gia hạn chứng thư cho từng người dùng. Đây là đầu tư về tổ chức và con người, không phải chỉ cài một phần mềm.
- Không dùng được với **giao diện web** của các dịch vụ thư phổ biến; đòi hỏi máy khách thư truyền thống.
- Chi phí và thủ tục cấp chứng thư làm cho việc triển khai ở quy mô một bộ môn hoặc một lớp học trở nên không khả thi.

3.3. Nhóm C — GnuPG kết hợp máy khách thư truyền thống

Là giải pháp mã hóa đầu cuối kinh điển, mạnh và trưởng thành.

Ưu điểm. Mã nguồn mở, được kiểm chứng lâu năm, không phụ thuộc nhà cung cấp nào, hoàn toàn tự chủ.

Nhược điểm chưa khắc phục được.

- **Rào cản sử dụng rất cao.** Thao tác chủ yếu qua dòng lệnh hoặc qua giao diện đồ họa mang nặng dấu ấn của mô hình dòng lệnh. Đây là nguyên nhân được ghi nhận rộng rãi khiến mã hóa thư điện tử không phổ cập được ngoài giới chuyên môn.
- **Không tích hợp với giao diện web.** Người dùng đang quen dùng Gmail trên trình duyệt phải chuyển sang một phần mềm khác, thay đổi thói quen làm việc.
- Giao diện tiếng Anh; thuật ngữ mang tính kỹ thuật cao.

3.4. Nhóm D — Tiện ích mở rộng trình duyệt (Mailvelope, FlowCrypt)

Đây là nhóm gần nhất với hướng tiếp cận của sáng kiến: giữ nguyên nhà cung cấp thư điện tử, bổ sung lớp mã hóa đầu cuối ngay trong trình duyệt. Mailvelope là phần mềm nguồn mở, giấy phép AGPL-3.0. FlowCrypt cũng là tiện ích trình duyệt cho Gmail.

Ưu điểm. Không phải đổi nhà cung cấp thư. Không cần hạ tầng mới. Dùng chuẩn OpenPGP nên liên thông tốt. Khóa riêng tư nằm tại máy người dùng.

Nhược điểm chưa khắc phục được — đây là những khoảng trống mà sáng kiến này nhắm vào. Các nhận định dưới đây đều được kiểm chứng trực tiếp trên mã nguồn, không dựa vào tài liệu quảng bá.

Bảng 2. Những hạn chế được kiểm chứng trên mã nguồn của nhóm D

Hạn chế	Bảng chứng kiểm chứng
Không có tiếng Việt. Mailvelope 6.3.0 cung cấp 15 ngôn ngữ (ar, de, en, es, fr, he, id, ja, km, lt, my, pt_BR, ru, tr, uk) và không có tiếng Việt. FlowCrypt không có cơ chế đa ngữ: thư mục <code>extension/</code> không chứa <code>_locales/</code> , giao diện chỉ tiếng Anh.	Đối chiếu trực tiếp thư mục <code>locales/</code> của mã nguồn Mailvelope tại commit <code>ffaa27af</code> (bản v6.3.0); liệt kê thư mục <code>extension/</code> của kho <code>FlowCrypt/flowcrypt-browser</code> , kiểm tra ngày 08/9/2026
Không cho phép chọn ngôn ngữ. Ngôn ngữ giao diện bị khóa cứng theo ngôn ngữ của trình duyệt, vì toàn bộ chuỗi hiển thị được phân giải qua <code>chrome.i18n</code> . Một người dùng dùng Chrome tiếng Anh không thể chuyển giao diện sang ngôn ngữ khác.	<code>src/lib/l10n.js</code> bản gốc: <code>export const get = chrome.i18n.getMessage;</code>
Mặc định tra cứu máy chủ khóa công cộng ở nước ngoài. Ba cơ chế tra cứu (máy chủ khóa của nhà phát triển, <code>keys.openpgp.org</code> , Web Key Directory) đều bật sẵn. Mỗi lần soạn thư cho một địa chỉ mới là một truy vấn ra ngoài, để lộ quan hệ	<code>src/res/defaults.json</code> bản gốc: <code>mvelo_tofu_lookup: true, oks_lookup: true, wkd_lookup: true</code>

liên lạc.	
Có bộ thư viện đo lường từ xa trong gói cài đặt. Bản gốc nhúng SDK Clean Insights trở tới <code>metrics.cleaninsights.org</code> . Tính năng bị tắt bằng một hằng số biên dịch, nhưng thư viện và địa chỉ máy chủ vẫn nằm trong gói phát hành, và giao diện vẫn có màn hình mời người dùng bật báo cáo.	<code>src/lib/analytics.js</code> bản gốc, dòng 6 và dòng 70; kiểm tra chuỗi <code>cleaninsights</code> trong gói đã biên dịch: 9 lần xuất hiện
Chặn tài khoản Google Workspace bằng kiểm tra giấy phép thương mại. Với tài khoản thuộc miền Workspace — chính là cấu hình mà một cơ quan sẽ dùng — phần mềm gửi tên miền và mã băm SHA-256 của định danh tài khoản Google về máy chủ cấp phép của nhà phát triển; nếu không có giấy phép thương mại, chức năng bị từ chối.	<code>src/modules/gmail.js</code> bản gốc: hàm <code>checkLicense</code> và <code>requestLicense</code> , hằng số <code>MVELO_BILLING_API_HOST</code>
Luồng xác thực OAuth không có PKCE. Bí mật client được ghi thẳng trong mã nguồn, mà bí mật này về bản chất không thể giữ kín trong một tiện ích trình duyệt. Không có cơ chế bù trừ.	<code>src/modules/gmail.js</code> bản gốc: hàm <code>getAuthCode</code> không có tham số <code>code_challenge</code>
Định danh tiện ích không cố định. Không khai báo khóa công khai trong manifest, nên Chrome sinh mã định danh từ đường dẫn cài đặt. Mỗi máy, mỗi thư mục cho một mã khác nhau, kéo theo URI chuyển hướng OAuth khác nhau — không đăng ký trước được, gây lỗi <code>redirect_uri_mismatch</code> khi triển khai.	<code>src/chrome/manifest.json</code> bản gốc: không có trường <code>key</code>

3.5. Nhóm E — Sản phẩm mật mã chuyên dụng của cơ quan có thẩm quyền

Cần trả lời câu hỏi tự nhiên nhất trong bối cảnh quân đội: *đã có sản phẩm mật mã của cơ quan có thẩm quyền, vì sao còn cần giải pháp này?*

Trả lời: **hai thứ phục vụ hai lớp thông tin khác nhau và không cạnh tranh nhau.**

- Đối với **thông tin thuộc danh mục bí mật nhà nước**, việc sử dụng sản phẩm mật mã của cơ quan có thẩm quyền là **bắt buộc theo quy định pháp luật**. Secure Mail không thay thế và không được đề xuất thay thế cho mục đích này (mục 12).
- Đối với **lớp thông tin còn lại** — tài liệu giảng dạy, đề thi chưa công bố, kết quả học tập, dữ liệu cá nhân của người học, bản thảo nghiên cứu, trao đổi nghiệp vụ hằng ngày — lớp này chiếm phần lớn khối lượng trao đổi, không thuộc danh mục bí mật nhà nước, nhưng vẫn cần được bảo vệ. Áp dụng quy trình và sản phẩm mật

mã chuyên dụng cho toàn bộ khối lượng này là quá tải về thủ tục và nguồn lực; thực tế nó dẫn tới việc lớp thông tin này được gửi bằng thư điện tử thông thường, tức là **không được bảo vệ gì cả**.

Khoảng trống mà sáng kiến lấp chính là lớp thứ hai: bảo vệ phần thông tin mà hiện nay đang được gửi ở dạng rõ vì chưa có công cụ đủ nhẹ và đủ dễ dùng.

Ngoài ra, riêng về mục đích **giảng dạy**, sản phẩm mật mã chuyên dụng không phù hợp làm học cụ: người học không tiếp cận được mã nguồn, không quan sát được cơ chế bên trong, không thực hành được các thao tác quản lý khóa. Secure Mail cho phép người học nhìn thấy toàn bộ quá trình — từ sinh khóa, đối chiếu dấu vân tay, đến việc cố ý sửa một ký tự trong bản mã để thấy hệ thống từ chối.

3.6. Nhận định chung về hiện trạng

Bảng 3. Đối chiếu bốn nhóm giải pháp với bốn điều kiện đặt ra

Điều kiện	A. Dịch vụ bảo mật	B. S/MIME	C. GnuPG	D. Tiện ích trình duyệt
Giữ nguyên nhà cung cấp thư điện tử	Không	Có	Có	Có
Không cần hạ tầng mới	Có	Không	Có	Có
Dùng được bằng tiếng Việt, không cần chuyên môn mật mã	Không	Không	Không	Không
Không tạo phụ thuộc mới vào bên thứ ba	Không	Một phần	Có	Không

Nhóm D đáp ứng được hai điều kiện đầu — đây là lý do hướng tiếp cận "tiện ích trình duyệt" là đúng. Nhưng nhóm D **không đáp ứng hai điều kiện sau**, và đó chính là khoảng trống mà sáng kiến này lấp.

Cần nói rõ: khoảng trống ở đây không phải là thiếu một thuật toán mật mã. Các thuật toán đã có, đã được chuẩn hóa, đã được kiểm chứng. Khoảng trống nằm ở chỗ **chưa có ai làm công việc kỹ thuật để biến chúng thành một sản phẩm dùng được trong điều kiện cụ thể của một đơn vị Việt Nam**: bằng tiếng Việt, với mô hình tin cậy do đơn vị kiểm soát, không kèm phụ thuộc thương mại, và kiểm chứng được.

4. Mục đích của giải pháp

Sáng kiến nhằm giải quyết bốn vấn đề cụ thể phát sinh từ thực tế nêu trên.

Mục đích 1 — Đưa mã hóa đầu cuối vào thao tác thường ngày mà không thay đổi hạ tầng. Người dùng tiếp tục dùng hộp thư và trình duyệt đang có; lớp mã hóa được bổ sung ngay trong trình duyệt. Không phải chuyển hộp thư, không phải dựng máy chủ, không phải cấp chứng thư số.

Mục đích 2 — Xóa rào cản ngôn ngữ trong công cụ mật mã. Toàn bộ giao diện, thông báo lỗi, hướng dẫn và cảnh báo an toàn bằng tiếng Việt, với hệ thuật ngữ nhất quán. Người dùng chọn được ngôn ngữ độc lập với ngôn ngữ trình duyệt.

Mục đích 3 — Đưa quyền kiểm soát mô hình tin cậy về đơn vị. Việc xác định "khóa công khai này đúng là của người này" phải do đơn vị chịu trách nhiệm qua kênh nội bộ đã xác thực, không giao phó cho máy chủ của bên thứ ba, và không để lộ quan hệ liên lạc ra ngoài.

Mục đích 4 — Bảo đảm tính kiểm chứng được. Mọi khẳng định về an toàn phải kiểm tra lại được bằng công cụ, trên chính bản phát hành. Trong lĩnh vực an toàn thông tin, một tuyên bố không kiểm chứng được thì không có giá trị.

Ngoài bốn mục đích trên, sáng kiến còn hướng tới một mục đích phái sinh nhưng quan trọng với công tác giảng dạy: **tạo ra một học cụ thực tế**, để người học thực hành mật mã ứng dụng trên chính công cụ đang được dùng trong công việc, và để hệ thuật ngữ mật mã tiếng Việt được dùng thống nhất giữa bài giảng và phần mềm.

PHẦN II. GIẢI PHÁP SECURE MAIL

5. Nguyên lý của giải pháp

5.1. Nguyên lý mật mã

Giải pháp dựa trên **mật mã lai (hybrid cryptography)** theo chuẩn OpenPGP, là mô hình đã được chuẩn hóa và kiểm chứng qua ba thập kỷ:

1. Mỗi người dùng có một **cặp khóa**: khóa công khai để người khác gửi thư cho mình, khóa riêng tư để tự mình giải mã. Khóa riêng tư được mã hóa bằng cụm mật khẩu và lưu trên máy người dùng.
2. Khi gửi thư, phần mềm sinh một **khóa phiên đối xứng** ngẫu nhiên, dùng khóa phiên đó mã hóa nội dung bằng AES-256, rồi mã hóa khóa phiên bằng khóa công khai của từng người nhận. Cách làm này kết hợp tốc độ của mã hóa đối xứng với tiện lợi phân phối khóa của mã hóa bất đối xứng.
3. Đồng thời phần mềm **ký số** nội dung bằng khóa riêng tư người gửi, cho phép người nhận xác minh nội dung không bị sửa và đúng là do người gửi tạo ra.
4. Cơ chế **kiểm tra toàn vẹn** của OpenPGP bảo đảm mọi sửa đổi lên bản mã đều bị phát hiện và bản mã bị từ chối, thay vì cho ra bản rõ sai.

Đây là phần mà sáng kiến **cố ý không thay đổi**. Lý do trình bày ở mục 6.1.

5.2. Nguyên lý kiến trúc: dịch chuyển ranh giới tin cậy

Nguyên lý kiến trúc cốt lõi là **dịch chuyển ranh giới tin cậy từ máy chủ về máy trạm**.

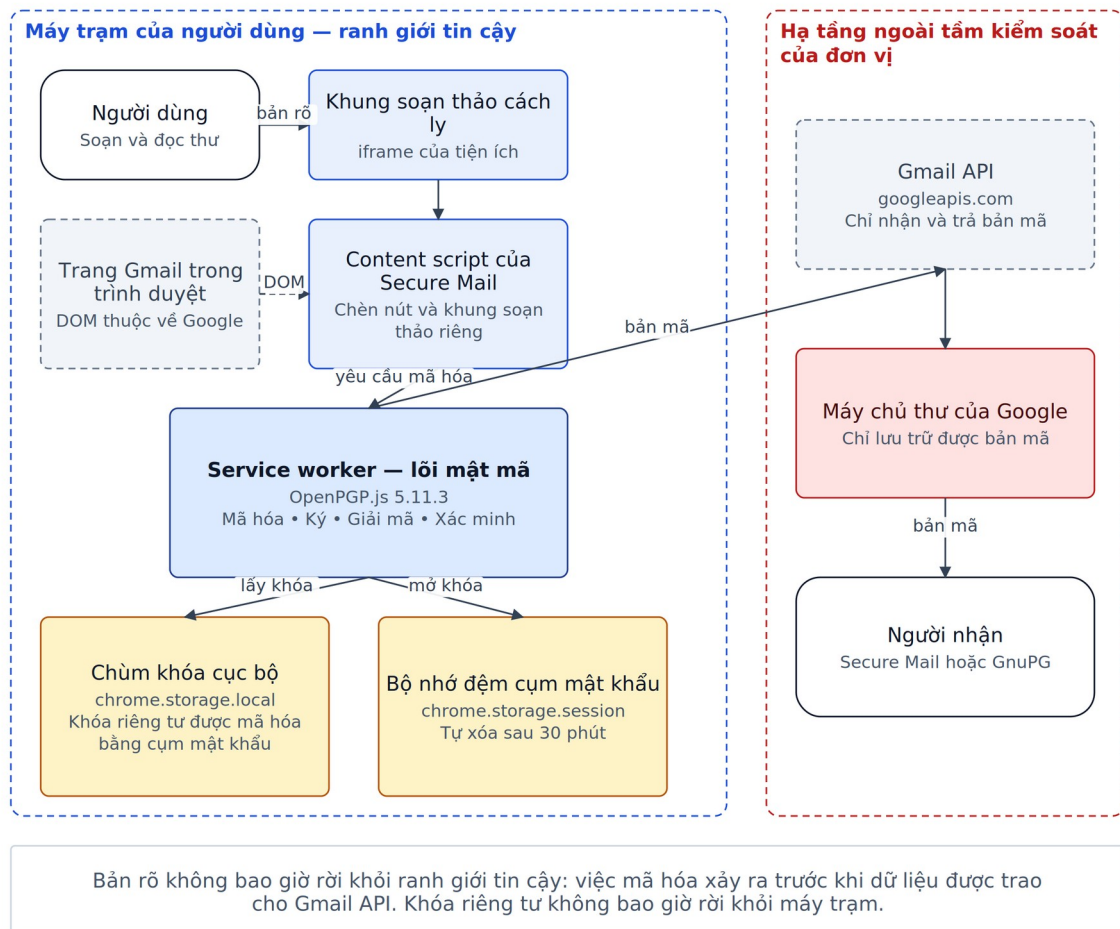
Trong mô hình thư điện tử thông thường, ranh giới tin cậy bao gồm cả máy chủ của nhà cung cấp: người dùng buộc phải tin rằng nhà cung cấp không đọc, không rò rỉ, không bị xâm nhập. Trong mô hình của Secure Mail, ranh giới tin cậy **chỉ gồm máy trạm của người dùng**. Nhà cung cấp thư điện tử bị đẩy ra ngoài ranh giới và được đối xử như một kênh truyền không tin cậy — nó vận chuyển và lưu trữ bản mã, không hơn.

Hệ quả của nguyên lý này chi phối mọi quyết định thiết kế còn lại:

- Nếu ranh giới tin cậy là máy trạm thì **khóa riêng tư không được rời khỏi máy trạm** trong bất kỳ hoàn cảnh nào.

- Nếu ranh giới tin cậy là máy trạm thì **bản rõ phải được mã hóa trước khi giao cho bất kỳ thành phần nào bên ngoài**, kể cả trước khi đưa vào ô soạn thảo của trang web nhà cung cấp. Đây là lý do Secure Mail dùng khung soạn thảo cách ly riêng thay vì mã hóa nội dung đã gõ vào ô của Gmail.
- Nếu ranh giới tin cậy là máy trạm thì **mọi kết nối ra ngoài đều là bề mặt tấn công tiềm tàng** và phải được kiểm đếm, giải thích, hoặc loại bỏ. Đây là lý do của toàn bộ mục 6.5.

Kiến trúc tổng thể Secure Mail trên nền Gmail



Hình 1. Kiến trúc tổng thể Secure Mail và vị trí của ranh giới tin cậy

5.3. Các yếu tố tác động đến giải pháp

Bốn yếu tố ràng buộc thiết kế và giải thích vì sao giải pháp có hình dạng như hiện nay:

Nền tảng trình duyệt. Tiện ích phải tuân thủ Manifest V3 của Chrome: mã nền chạy trong service worker có vòng đời ngắn, bị dừng khi rảnh. Điều này ảnh hưởng trực tiếp tới cách lưu trữ trạng thái và cách xử lý bộ nhớ đệm cụm mật khẩu.

Giao diện của nhà cung cấp thư điện tử. Giao diện web của Gmail thay đổi theo thời gian; phần chèn giao diện phải bám vào cấu trúc trang. Đây là điểm dễ tổn thương nhất về mặt bảo trì, và là lý do phần lõi mật mã được tách rời hoàn toàn khỏi phần chèn giao diện.

Chính sách của nhà cung cấp định danh. Việc truy cập Gmail API qua OAuth 2.0 đòi hỏi đăng ký ứng dụng, phạm vi quyền và URI chuyển hướng cố định. Ràng buộc này quyết định thiết kế ở mục 6.6.

Yêu cầu thực tế của người dùng. Người dùng không phải chuyên gia mật mã. Mọi thao tác đòi hỏi hiểu biết kỹ thuật đều là điểm mà giải pháp sẽ thất bại trong thực tế. Nguyên tắc thiết kế: mặc định phải an toàn, và mặc định phải dùng được ngay mà không cần cấu hình.

6. Các nội dung chủ yếu

6.1. Nền tảng kỹ thuật và quyết định kế thừa

Secure Mail được xây dựng trên nền phần mềm nguồn mở Mailvelope phiên bản 6.3.0 (giấy phép AGPL-3.0). Đây là một quyết định kỹ thuật có chủ đích, cần được trình bày rõ ràng vì nó ảnh hưởng tới cách đánh giá tính mới của sáng kiến.

Vì sao không viết lại từ đầu. Trong an toàn thông tin, việc tự viết lại phần lõi mật mã là một trong những sai lầm được cảnh báo nhiều nhất. Một thư viện mật mã đúng về mặt thuật toán vẫn có thể sai về mặt hiện thực: rò rỉ qua thời gian thực thi, xử lý sai trường hợp biên, sinh số ngẫu nhiên yếu, quản lý bộ nhớ không an toàn. Những lỗi này chỉ bộc lộ sau nhiều năm được cộng đồng soi xét. Viết lại lõi mật mã để "cho có tính mới" sẽ làm giảm độ an toàn thực tế của sản phẩm — đi ngược mục tiêu của chính sáng kiến.

Vì sao vẫn là một sáng kiến. Giá trị của sáng kiến không nằm ở việc tạo ra thuật toán mới, mà nằm ở **công việc kỹ thuật biến một phần mềm không dùng được trong điều kiện của đơn vị thành một phần mềm dùng được**. Toàn bộ những hạn chế nêu tại Bảng 2 — không tiếng Việt, không chọn được ngôn ngữ, mặc định rò rỉ

siêu dữ liệu, kèm thư viện đo lường từ xa, chặn tài khoản Workspace, xác thực thiếu an toàn, định danh không ổn định — đều là **rào cản chặn đứng việc triển khai**, và tất cả đều đã được xử lý trong sáng kiến này.

Bảo đảm tuân thủ giấy phép và ghi nhận nguồn gốc. Mã nguồn gốc thuộc giấy phép AGPL-3.0; sáng kiến giữ nguyên toàn bộ thông báo bản quyền và giấy phép trong LICENSE, THIRD_PARTY_NOTICES.md và trong tiêu đề từng tệp mã nguồn. Nguồn gốc được ghi lại chính xác trong SOURCE_SNAPSHOT.md: kho nguồn gốc, nhãn phiên bản v6.3.0, mã commit ffaa27afb384b735036aa2d20ace09c2b609bffd, thời điểm sao chép. Đây là yêu cầu bắt buộc của giấy phép, đồng thời là chuẩn mực liêm chính học thuật.

Quy mô đóng góp. Bảng dưới đây đo trực tiếp bằng cách so sánh cây mã nguồn hiện tại với bản gốc tại commit đã nêu.

Bảng 4. Quy mô thay đổi so với bản gốc Mailvelope 6.3.0

Hạng mục	Số liệu	Cách đo
Số tệp mã nguồn được sửa đổi	36 tệp	<code>diff -rq</code> giữa hai cây mã nguồn
Số tệp được gỡ bỏ hoàn toàn	3 tệp (màn hình xin phép thu thập dữ liệu, mục cài đặt đo lường, phép thử cũ đi kèm)	<code>diff -rq</code>
Số dòng được thêm / gỡ bỏ trong các tệp đó	+426 / -553	<code>diff -u</code> từng tệp
Tệp mới hoàn toàn: danh mục ngôn ngữ tiếng Việt	1.880 dòng, 586 mục dịch	<code>wc -l locales/vi/messages.json</code>
Tệp mới hoàn toàn: bộ kịch bản kiểm chứng	5 tệp, 637 dòng	<code>wc -l</code> trên 4 kịch bản trong <code>mailvelope/scripts/</code> và 1 trong <code>mobile/scripts/</code>
Tệp mới hoàn toàn: kịch bản chụp ảnh tài liệu	2 tệp, 275 dòng	<code>wc -l mailvelope/scripts/capture-*.mjs</code>
Tệp mới hoàn toàn: bộ biểu tượng nhận diện	11 tệp (1 SVG gốc, 10 kích thước PNG)	<code>ls src/img/secure-mail/</code>
Dự án phiên bản di động (kho riêng)	52 tệp, 2.084 dòng mã	<code>git ls-files</code> trên kho <code>mobile/</code>
Tài liệu hướng dẫn và quy trình bằng tiếng Việt	9 tệp trong <code>docs/internal/</code>	<code>ls docs/internal/</code>

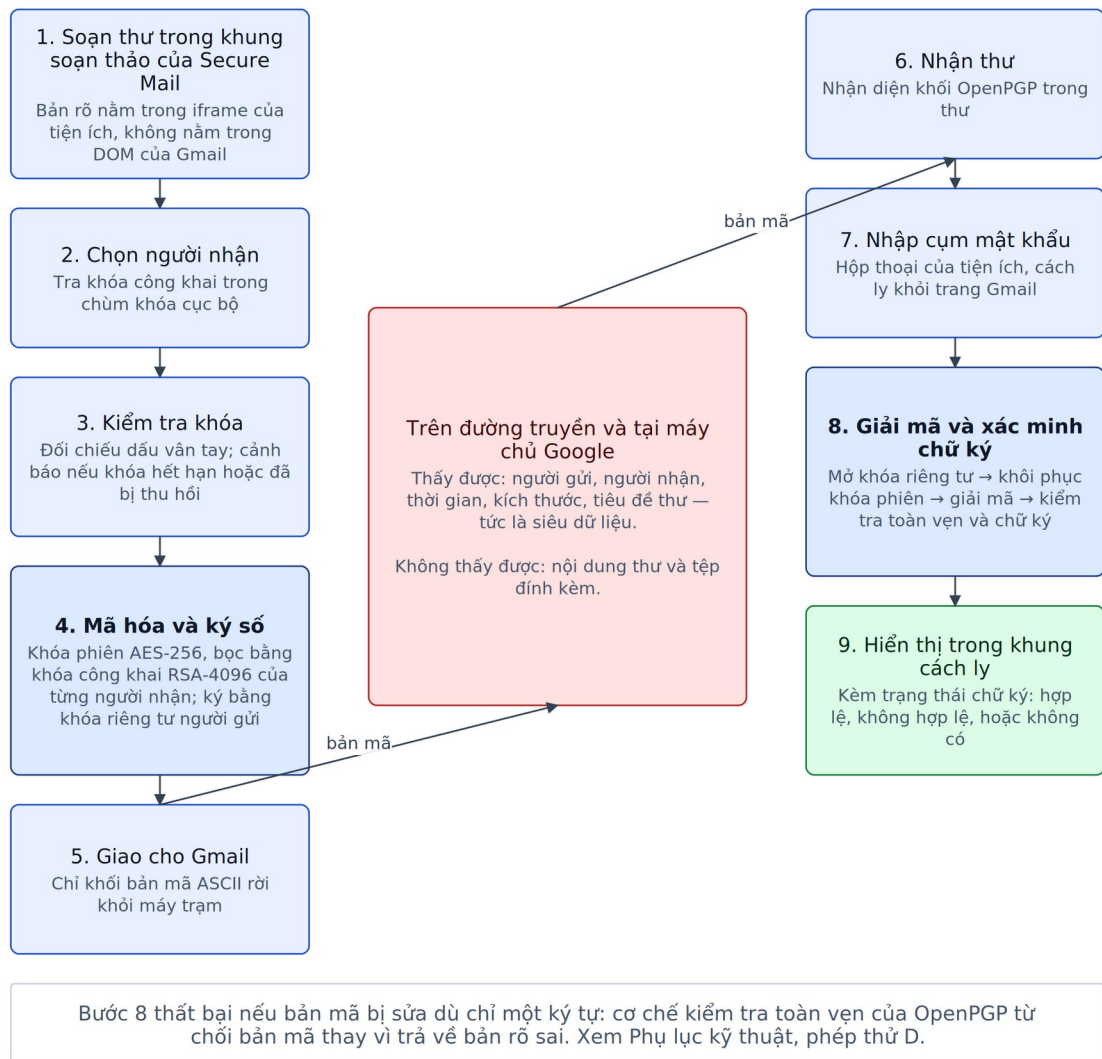
Con số "+426 dòng" nhìn có vẻ nhỏ, nhưng đây là đặc trưng của công việc cải tạo hệ thống có sẵn: giá trị nằm ở chỗ **thay đổi đúng chỗ**, không nằm ở khối lượng. Riêng việc gỡ bỏ 553 dòng đã loại được hai kênh liên lạc ra bên thứ ba khỏi sản phẩm. Phần đóng góp có khối lượng lớn — 1.880 dòng bản dịch, 912 dòng kịch bản kiểm chứng và chụp ảnh tài liệu, 2.084 dòng mã cho phiên bản di động — nằm ở các tệp mới.

6.2. Mã hóa đầu cuối tích hợp trong giao diện Gmail

Cơ chế hoạt động: một đoạn mã (content script) được nạp vào trang Gmail, nhận diện ô soạn thư và các thư có chứa khối OpenPGP, rồi chèn thêm các nút điều khiển của Secure Mail. Toàn bộ thao tác mật mã **không diễn ra trong đoạn mã này** mà được chuyển cho service worker của tiện ích — một môi trường tách biệt hoàn toàn khỏi trang web.

Sự tách biệt này là điểm thiết kế quan trọng. Đoạn mã chèn vào trang Gmail chạy trong cùng nguồn gốc (origin) với trang của Google. Nếu bản rõ hoặc khóa đi qua đó, một lỗ hổng trên trang Gmail sẽ trở thành lỗ hổng của Secure Mail. Vì vậy:

- Bản rõ được nhập trong một **khung soạn thảo cách ly** thuộc về tiện ích, không phải ô soạn thảo của Gmail.
- Bản rõ khi giải mã cũng được hiển thị trong **khung cách ly**, không chèn vào cây DOM của Gmail.
- Cụm mật khẩu được nhập trong **hộp thoại của tiện ích**.
- Khóa và bản rõ chỉ tồn tại trong service worker và trong các khung cách ly.

Luồng xử lý một bức thư mã hóa (gửi và nhận)

Hình 2. Luồng xử lý một bức thư mã hóa, từ khi soạn đến khi người nhận đọc được

Từ góc nhìn của Google, một bức thư gửi qua Secure Mail chỉ là một khối văn bản ASCII không đọc được. Google vẫn thấy **siêu dữ liệu** — ai gửi, gửi cho ai, lúc nào, kích thước bao nhiêu, tiêu đề thư là gì — vì đó là thông tin mà giao thức thư điện tử bắt buộc phải để lộ để định tuyến được. Hồ sơ này nêu rõ giới hạn đó thay vì che giấu; xem thêm mục 12.

6.3. Bản địa hóa tiếng Việt và cơ chế chọn ngôn ngữ

Đây là nội dung có khối lượng lớn nhất và có tác động trực tiếp nhất tới người dùng.

6.3.1. Vấn đề kiến trúc phải giải trước

Bản gốc phân giải mọi chuỗi hiển thị qua `chrome.i18n`, cơ chế đa ngữ sẵn có của trình duyệt. Cơ chế này chọn ngôn ngữ **theo ngôn ngữ giao diện của trình duyệt** và không cho phép ứng dụng ghi đè. Chỉ thêm một thư mục `locales/vi/` là không đủ: người dùng dùng Chrome tiếng Anh — trường hợp rất phổ biến — sẽ không bao giờ thấy giao diện tiếng Việt, và không có cách nào để chọn.

Ràng buộc kỹ thuật: bảng chuỗi hiển thị được nạp **đồng bộ** ngay khi mô-đun được tải, trước khi bất kỳ lệnh chờ nào có thể chạy. Vì vậy không thể đọc lựa chọn ngôn ngữ từ `chrome.storage` (là API bất đồng bộ).

6.3.2. Giải pháp

Lớp `src/lib/l10n.js` được viết lại: cả hai danh mục ngôn ngữ (Anh và Việt) được đóng gói thẳng vào bản phát hành, và một bộ phân giải mới thay thế lời gọi `chrome.i18n`. Lựa chọn ngôn ngữ được đọc từ `localStorage` — là API đồng bộ, và có phạm vi theo nguồn gốc nên mọi trang của tiện ích (trang tùy chọn, khung soạn thảo, hộp thoại mật khẩu, phiếu khôi phục) đều dùng chung một thiết lập.

Thứ tự phân giải một chuỗi được thiết kế để không bao giờ để lại ô trống trên giao diện:

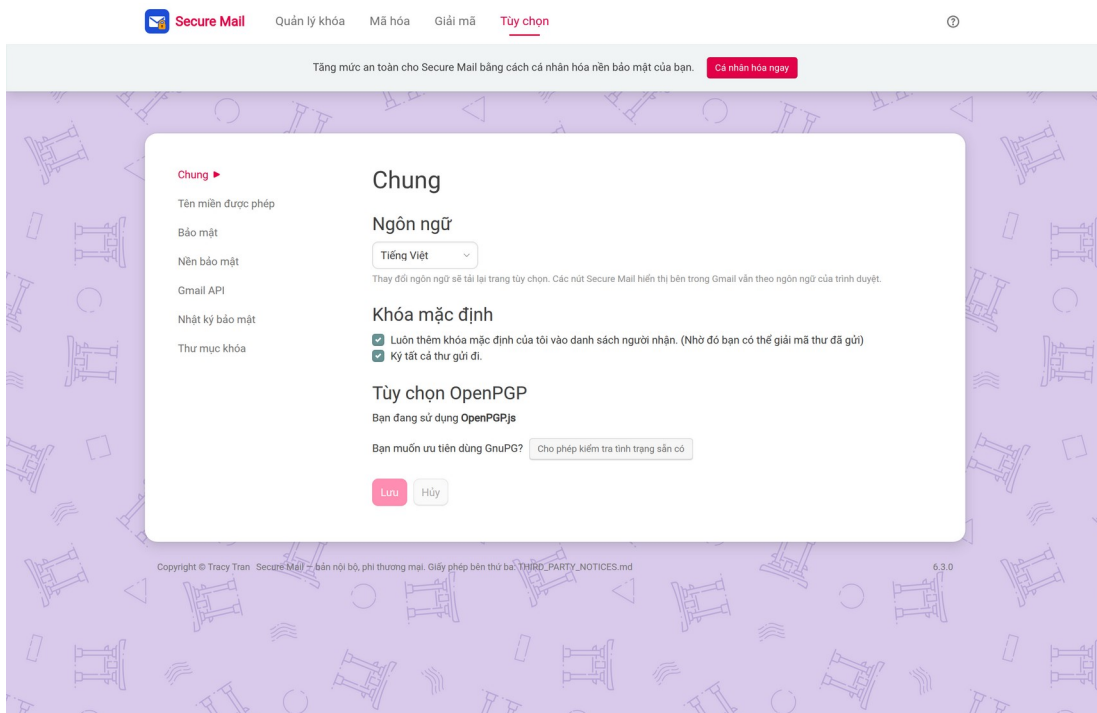
5. Danh mục ngôn ngữ người dùng đã chọn;
6. nếu thiếu, lùi về danh mục tiếng Anh;
7. nếu vẫn thiếu, hỏi `chrome.i18n` — giữ nguyên khả năng hoạt động cho 14 ngôn ngữ còn lại của bản gốc;
8. nếu vẫn thiếu, hiển thị chính mã khóa của chuỗi, để một thiếu sót về dịch thuật hiện ra rõ ràng thay vì biến thành ô trống khó truy vết.

Bước 3 đáng chú ý: giải pháp **bổ sung** khả năng chọn ngôn ngữ mà **không phá vỡ** cơ chế đa ngữ sẵn có. Người dùng ở 14 ngôn ngữ khác vẫn thấy giao diện ngôn ngữ của họ như trước.

Người dùng chọn ngôn ngữ tại **Tùy chọn** → **Chung** → **Ngôn ngữ**, với ba lựa chọn: theo trình duyệt (mặc định), English, Tiếng Việt.

Một giới hạn cần nêu rõ. Các nút mà Secure Mail chèn **vào bên trong trang Gmail** vẫn theo ngôn ngữ của trình duyệt, không theo lựa chọn này. Nguyên nhân là

kiến trúc: đoạn mã chèn vào trang chạy trong nguồn gốc (origin) của Gmail, nơi nó không đọc được vùng lưu trữ cục bộ thuộc về tiện ích — và việc cho nó đọc được sẽ phá vỡ chính sự cách ly đã trình bày ở mục 6.2. Đây là một đánh đổi có ý thức, nghiêng về phía an toàn. Phạm vi ảnh hưởng nhỏ: các nút này chỉ mang vài nhãn ngấn, còn toàn bộ nội dung người dùng thực sự phải đọc — trang tùy chọn, khung soạn thảo, hộp thoại mật khẩu, phiếu khôi phục, mọi thông báo lỗi và cảnh báo an toàn — đều nằm trong các trang của tiện ích và đổi theo lựa chọn ngôn ngữ.



Hình 3. Bộ chọn ngôn ngữ trong trang Tùy chọn, giao diện đang ở tiếng Việt

6.3.3. Bộ thuật ngữ mật mã tiếng Việt

Phần khó nhất của bản địa hóa một phần mềm mật mã không phải là dịch câu, mà là **chuẩn hóa thuật ngữ**. Một khái niệm được dịch hai cách khác nhau ở hai màn hình sẽ dạy người dùng hai khái niệm khác nhau — hậu quả đặc biệt nghiêm trọng với một sản phẩm đồng thời là học cụ.

Bộ thuật ngữ được thống nhất và áp dụng nhất quán trên toàn bộ 586 chuỗi:

Bảng 5. Bộ thuật ngữ mật mã tiếng Việt được áp dụng nhất quán

Thuật ngữ gốc	Thuật ngữ tiếng Việt	Ghi chú lựa chọn
private key	khóa riêng tư	Chọn "riêng tư" thay vì "bí mật" để tránh nhầm với "bí mật nhà nước"; nhấn vào tính

		sở hữu cá nhân
public key	khóa công khai	
key pair	cặp khóa	
keyring	chùm khóa	Trong nhãn điều hướng dùng "Quản lý khóa" vì đó là hành động người dùng thực hiện
passphrase	cụm mật khẩu	Phân biệt rõ với "mật khẩu" (password) — hai khái niệm khác nhau về độ dài và mục đích
fingerprint	dấu vân tay	Giữ kèm từ gốc trong ngoặc ở lần xuất hiện đầu, để người học nổi được với tài liệu tiếng Anh
revoke	thu hồi	
subkey	khóa phụ	
recovery sheet	phiếu khôi phục	
user ID	định danh người dùng	
encrypt / decrypt	mã hóa / giải mã	
sign / signature	ký / chữ ký số	
verify	xác minh	Phân biệt với "kiểm tra" (check)
backup / restore	sao lưu / khôi phục	

Tên riêng và tên chuẩn quốc tế (OpenPGP, GnuPG, Gmail, PKCE, WKD) được giữ nguyên — dịch chúng sẽ làm người dùng mất khả năng tra cứu tài liệu gốc.

6.3.4. Kiểm toán chất lượng bản dịch bằng công cụ

Dịch 586 chuỗi thủ công chắc chắn phát sinh sai sót, và những sai sót nguy hiểm nhất lại không nhìn thấy được khi đọc lướt. Vì vậy sáng kiến xây dựng một kịch bản kiểm toán (`scripts/verify-translation.mjs`) kiểm tra năm nhóm lỗi:

9. **Độ phủ** — mọi mã khóa tiếng Anh phải có bản dịch tiếng Việt.
10. **Ô thay thế** — các vị trí \$1, \$2 dùng để chèn giá trị động phải được giữ nguyên; mất một ô thay thế nghĩa là một thông báo mất đi giá trị mà nó cần hiển thị.
11. **Thẻ đánh dấu** — các thẻ `<0>...</0>` dùng để chèn liên kết và nút bấm phải khớp; sai thẻ làm giao diện dựng sai cấu trúc.
12. **Nhất quán thuật ngữ** — mỗi thuật ngữ trong bảng trên phải được dịch đúng một cách.

13. **Chuỗi chưa dịch** — giá trị trùng hệt tiếng Anh mà không phải danh từ riêng.

Kịch bản này đã phát hiện **sáu lỗi thực** trong quá trình xây dựng hồ sơ, trong đó có hai lỗi ảnh hưởng trực tiếp tới an toàn:

- Chuỗi hướng dẫn sau khi tạo khóa đã **bỏ mất câu yêu cầu gửi khóa công khai và dấu vân tay cho quản trị viên qua kênh đã xác thực** — tức là bỏ mất chính bước bảo đảm tính xác thực của khóa.
- Chuỗi hướng dẫn về liên hệ tin cậy đã **bỏ mất khuyến cáo phải tự xác minh danh tính** đối với liên hệ dùng địa chỉ thư của nhà cung cấp khác.
- Một chuỗi mất hai trong ba ô thay thế \$1.
- Thuật ngữ "private key" được dịch không nhất quán ở 7 chuỗi ("khóa bí mật" lẫn với "khóa riêng tư").

Cả sáu lỗi đã được sửa. Kết quả kiểm toán sau khi sửa: **586/586 chuỗi (100%), 0 lỗi chặn**. Toàn văn kết quả tại Phụ lục kỹ thuật, mục A.4.

Cần nhấn mạnh: việc **tự phát hiện và công bố** những lỗi này là một phần của phương pháp làm việc, không phải điểm yếu. Một sản phẩm an toàn không phải là sản phẩm không có lỗi, mà là sản phẩm có cơ chế phát hiện lỗi và cơ chế đó chạy được lặp lại.

6.4. Mô hình tin cậy khép kín do đơn vị kiểm soát

6.4.1. Vấn đề

Mật mã khóa công khai giải được bài toán bí mật, nhưng để lại một bài toán khó hơn: **làm sao biết khóa công khai này đúng là của người kia?** Nếu kẻ tấn công đưa được khóa của mình vào chỗ khóa của người nhận, hẳn đọc được toàn bộ thư — mọi thuật toán mạnh đều vô nghĩa.

Bản gốc giải bài toán này bằng cách tra cứu máy chủ khóa công cộng theo mô hình TOFU (tin vào khóa gặp lần đầu). Mô hình này có hai nhược điểm nghiêm trọng trong bối cảnh của đơn vị:

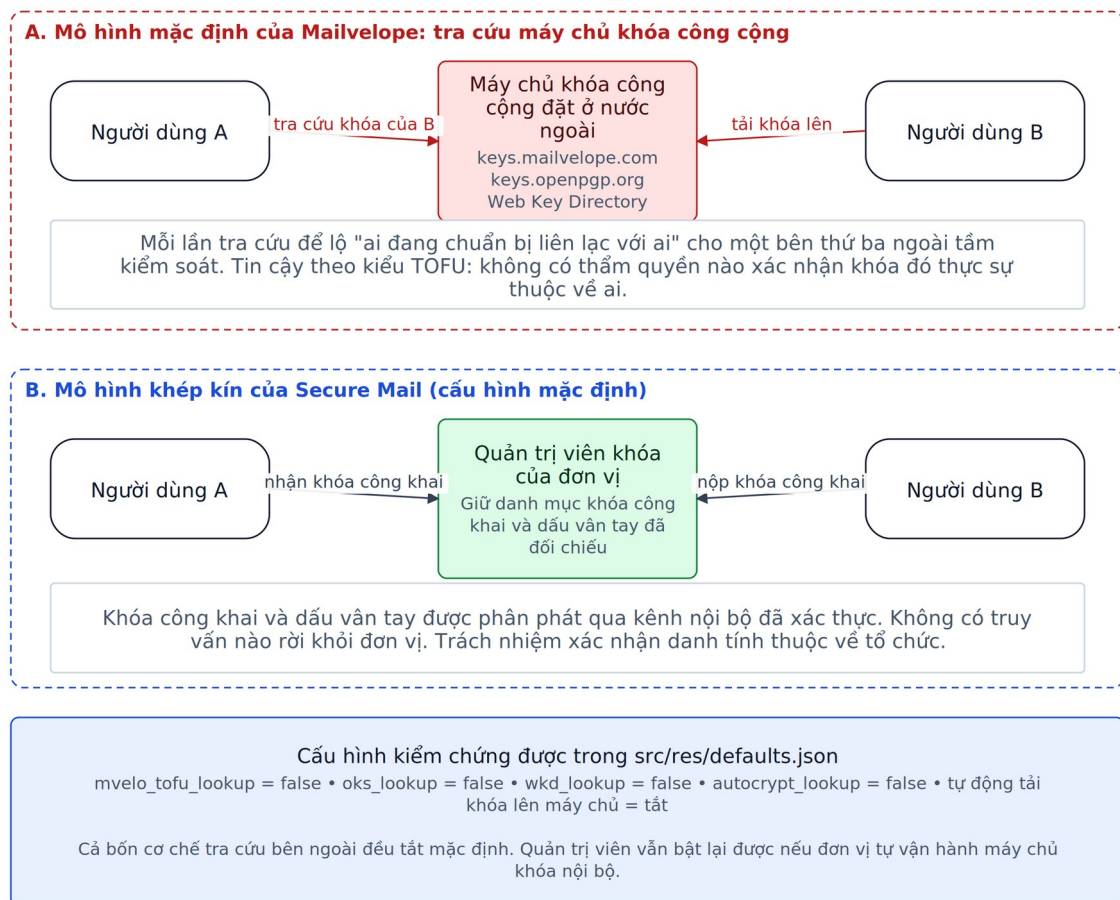
- **Rò rỉ siêu dữ liệu quan hệ.** Mỗi lần tra cứu là một lần thông báo cho một máy chủ ở nước ngoài rằng "người này sắp liên lạc với người kia". Với một cơ quan, tập hợp các quan hệ liên lạc là thông tin có giá trị tình báo độc lập với nội dung.

- **Không có thẩm quyền xác nhận.** TOFU chỉ ghi nhận, không xác nhận. Không ai chịu trách nhiệm về việc khóa đó có đúng là của người đó hay không.

6.4.2. Giải pháp

Secure Mail chuyển sang **mô hình phân phối khóa khép kín**: toàn bộ bốn cơ chế tra cứu bên ngoài được tắt mặc định, và trách nhiệm xác nhận danh tính được giao cho đơn vị — nơi vốn đã có thẩm quyền và quy trình để làm việc đó.

Hai mô hình phân phối khóa công khai



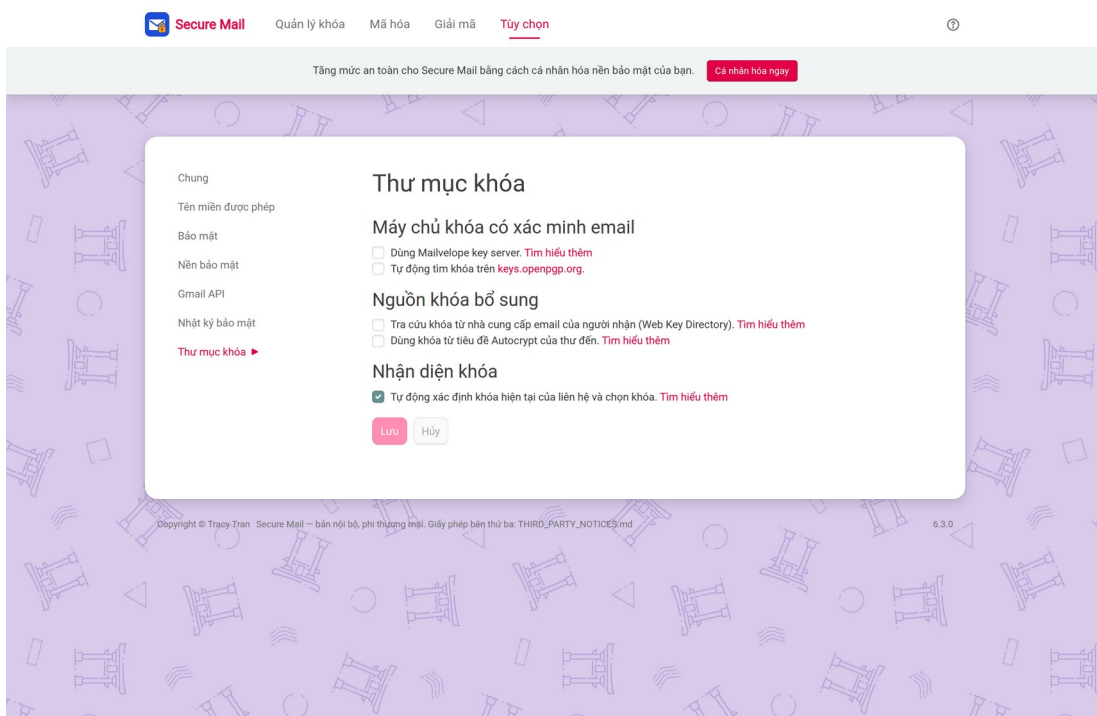
Hình 4. So sánh hai mô hình phân phối khóa công khai

Quy trình quản trị đi kèm được tài liệu hóa bằng tiếng Việt trong docs/internal/ADMIN_PUBLIC_KEY_MANAGEMENT_VI.md, kèm mẫu danh mục khóa dạng CSV và tệp khóa công khai mẫu:

14. Người dùng sinh cặp khóa trên máy của mình. **Khóa riêng tư không bao giờ rời khỏi máy đó.**

15. Người dùng gửi **khóa công khai và dấu vân tay** cho quản trị viên qua kênh nội bộ đã xác thực.
16. Quản trị viên **đối chiếu dấu vân tay** trực tiếp với người dùng, ghi vào danh mục khóa của đơn vị.
17. Quản trị viên phát hành danh mục khóa cho các thành viên.
18. Người dùng nhập khóa công khai từ danh mục đó.

Điểm cần nhấn mạnh về nguyên tắc: **quản trị viên chỉ quản lý khóa công khai và dấu vân tay, không bao giờ giữ khóa riêng tư của người dùng**. Nếu quản trị viên giữ khóa riêng tư, mô hình mã hóa đầu cuối sụp đổ — quản trị viên trở thành một điểm đọc được mọi thư. Nguyên tắc này được nêu ngay trong giao diện, bằng tiếng Việt, tại màn hình thiết lập ban đầu, để người dùng biết rằng bất kỳ yêu cầu nộp khóa riêng tư nào cũng là dấu hiệu bất thường.



Hình 5. Màn hình Thư mục khóa: cả bốn cơ chế tra cứu bên ngoài đều ở trạng thái tắt

Cấu hình này **kiểm chứng được**: các giá trị `mvelo_tofu_lookup`, `oks_lookup`, `wkd_lookup`, `autocrypt_lookup` trong `src/res/defaults.json` đều bằng `false`, và Hình 5 cho thấy trạng thái thực tế trên giao diện.

Giải pháp **không xóa bỏ** khả năng dùng máy chủ khóa: nếu về sau đơn vị tự vận hành một máy chủ khóa nội bộ hoặc một Web Key Directory trên tên miền của mình,

quản trị viên bật lại được. Đây là lựa chọn có ý thức — giữ khả năng mở rộng, nhưng đặt mặc định ở trạng thái an toàn nhất.

6.5. Cắt bỏ phụ thuộc vào bên thứ ba

Nguyên lý ở mục 5.2 đòi hỏi mọi kết nối ra ngoài phải được kiểm đếm và giải thích. Rà soát toàn bộ mã nguồn cho thấy hai kênh liên lạc ra bên thứ ba mà người dùng không nhận biết được và không thể loại bỏ bằng cấu hình. Cả hai đã được **gỡ bỏ khỏi mã nguồn**, không phải chỉ tắt bằng tùy chọn.

6.5.1. Gỡ bỏ thư viện đo lường từ xa

Bản gốc nhúng SDK Clean Insights trỏ tới `metrics.cleaninsights.org`, kèm màn hình mời người dùng bật báo cáo. Tính năng bị vô hiệu bằng một hằng số biên dịch (`ciActive = false`), nhưng thư viện, định nghĩa chiến dịch thu thập và địa chỉ máy chủ vẫn nằm nguyên trong gói phát hành.

Với một sản phẩm dùng trong đơn vị, "đang tắt" và "không tồn tại" là hai mức bảo đảm khác nhau về bản chất. Một hằng số có thể bị bật lại bởi một lần cập nhật từ thượng nguồn; và người thẩm định không thể phân biệt "tắt" với "không có" nếu không đọc mã nguồn. Vì vậy:

- Mô-đun `src/lib/analytics.js` được thay bằng bản rỗng, giữ nguyên danh sách hàm xuất để mọi nơi gọi tới vẫn hoạt động, nhưng mọi điểm vào đều trơ.
- Gói phụ thuộc `clean-insights-sdk` được gỡ khỏi `package.json`.
- Màn hình xin phép thu thập dữ liệu và mục cài đặt tương ứng được gỡ khỏi giao diện — giữ lại một tùy chọn cho một tính năng không tồn tại chỉ gây nhầm lẫn.

6.5.2. Gỡ bỏ cơ chế kiểm tra giấy phép thương mại

Đây là thay đổi có tác động thực tế lớn nhất về mặt triển khai.

Bản gốc, với tài khoản thuộc miền Google Workspace, gọi hàm `checkLicense`: gửi tên miền Workspace và mã băm SHA-256 của định danh tài khoản Google về máy chủ cấp phép của nhà phát triển; nếu không có giấy phép thương mại thì **từ chối thực hiện chức năng**.

Hai lý do khiến cơ chế này không thể tồn tại trong sản phẩm:

- **Về chủ quyền dữ liệu.** Nó gửi một định danh tổ chức và một biệt danh ổn định của từng người dùng ra bên thứ ba, trong mỗi lần cấp quyền. Điều này mâu thuẫn trực tiếp với tiền đề triển khai.
- **Về tính sẵn sàng.** Một cơ quan dùng tên miền Workspace — trường hợp phổ biến nhất — sẽ **không đọc được thư của chính mình** mỗi khi máy chủ cấp phép của bên thứ ba không truy cập được hoặc giấy phép hết hạn. Khả năng đọc dữ liệu đã mã hóa của mình không được phép phụ thuộc vào một dịch vụ thương mại bên ngoài.

Hàm `checkLicense` được giữ lại (các nơi gọi vẫn còn) nhưng trở thành hàm rỗng. Toàn bộ mã gửi yêu cầu, hằng số địa chỉ máy chủ, các trường dữ liệu lưu định danh tài khoản Google, và giao diện bán giấy phép đều bị gỡ bỏ.

6.5.3. Kiểm chứng bằng công cụ

Việc gỡ bỏ được kiểm chứng bằng kịch bản `scripts/verify-no-external-endpoints.sh`, chạy trên **bản đã biên dịch** — nghĩa là kiểm tra sản phẩm thật, không phải kiểm tra ý định trong mã nguồn.

Bảng 6. Kết quả kiểm toán bề mặt mạng, đo trên gói phát hành

Điểm cuối bên thứ ba	Bản trước khi cải tạo	Bản phát hành v0.3.0
<code>cleaninsights</code> (thư viện đo lường)	9 lần xuất hiện	0
<code>metrics.cleaninsights.org</code>	có	0
<code>license.mailvelope.com</code> (kiểm tra giấy phép)	1 lần xuất hiện	0
<code>mailvelope.com/google-workspace</code> (trang bán hàng)	1 lần xuất hiện	0
Kết luận		ĐẠT — 4/4

Kịch bản đồng thời liệt kê **toàn bộ** các điểm phát sinh kết nối mạng còn lại trong mã nguồn, để người thẩm định đối chiếu thay vì phải tin:

Bảng 7. Toàn bộ bề mặt mạng còn lại của sản phẩm

Máy chủ	Mục đích	Trạng thái
<code>accounts.google.com</code>	Đăng nhập Gmail	Bật — là tính năng đang dùng
<code>oauth2.googleapis.co</code>	Trao đổi token OAuth	Bật — là tính năng đang dùng

m		
www.googleapis.com	Gmail API, thông tin tài khoản	Bật — là tính năng đang dùng
keys.mailvelope.com	Máy chủ khóa công cộng	Tắt mặc định
keys.openpgp.org	Máy chủ khóa công cộng	Tắt mặc định
Tên miền người nhận (WKD)	Tra khóa theo tên miền	Tắt mặc định
chrome-extension://<id>/...	Nạp tệp đồ họa đóng gói sẵn	Cục bộ, không ra mạng

Nói cách khác: **sau khi cài tạo, ngoài chính Gmail — dịch vụ mà người dùng chủ động chọn dùng — sản phẩm không liên lạc với bất kỳ máy chủ nào khác ở cấu hình mặc định.**

6.6. Xác thực Gmail API an toàn và triển khai được

Để đọc và gửi thư qua Gmail API, tiện ích phải được người dùng cấp quyền qua OAuth 2.0. Bản gốc có hai vấn đề khiến việc triển khai thực tế không thực hiện được.

6.6.1. Vấn đề thứ nhất: định danh tiện ích không ổn định

Chrome sinh mã định danh cho tiện ích cài ở chế độ nhà phát triển bằng cách băm **đường dẫn thư mục cài đặt**. Hệ quả: cùng một bản phát hành, cài ở hai máy khác nhau hoặc hai thư mục khác nhau sẽ nhận hai mã định danh khác nhau.

Mã định danh này lại quyết định URI chuyển hướng OAuth (<https://<mã định danh>.chromiumapp.org/>), mà URI chuyển hướng thì phải đăng ký trước với Google. Không thể đăng ký trước một giá trị thay đổi theo từng máy. Đây là nguyên nhân gốc của lỗi `redirect_uri_mismatch` — lỗi chặn đứng việc triển khai.

Giải pháp: khai báo khóa công khai RSA cố định trong trường `key` của manifest. Chrome khi đó dẫn xuất mã định danh từ khóa này thay vì từ đường dẫn. Kết quả: mã định danh trở thành hằng số `ihhialmbgcagicfabjkijbpbppggbnebe` trên **mọi máy, mọi thư mục cài đặt** — đăng ký được một lần với Google và dùng cho toàn đơn vị.

Đây là chuyển một thuộc tính ngẫu nhiên theo môi trường thành một **hằng số triển khai**. Ngoài việc sửa lỗi, nó còn cho một lợi ích về an toàn: mã định danh trở thành một đại lượng kiểm chứng được — người quản trị đối chiếu mã định danh hiển thị trong `chrome://extensions` với giá trị công bố để phát hiện bản cài đặt giả mạo.

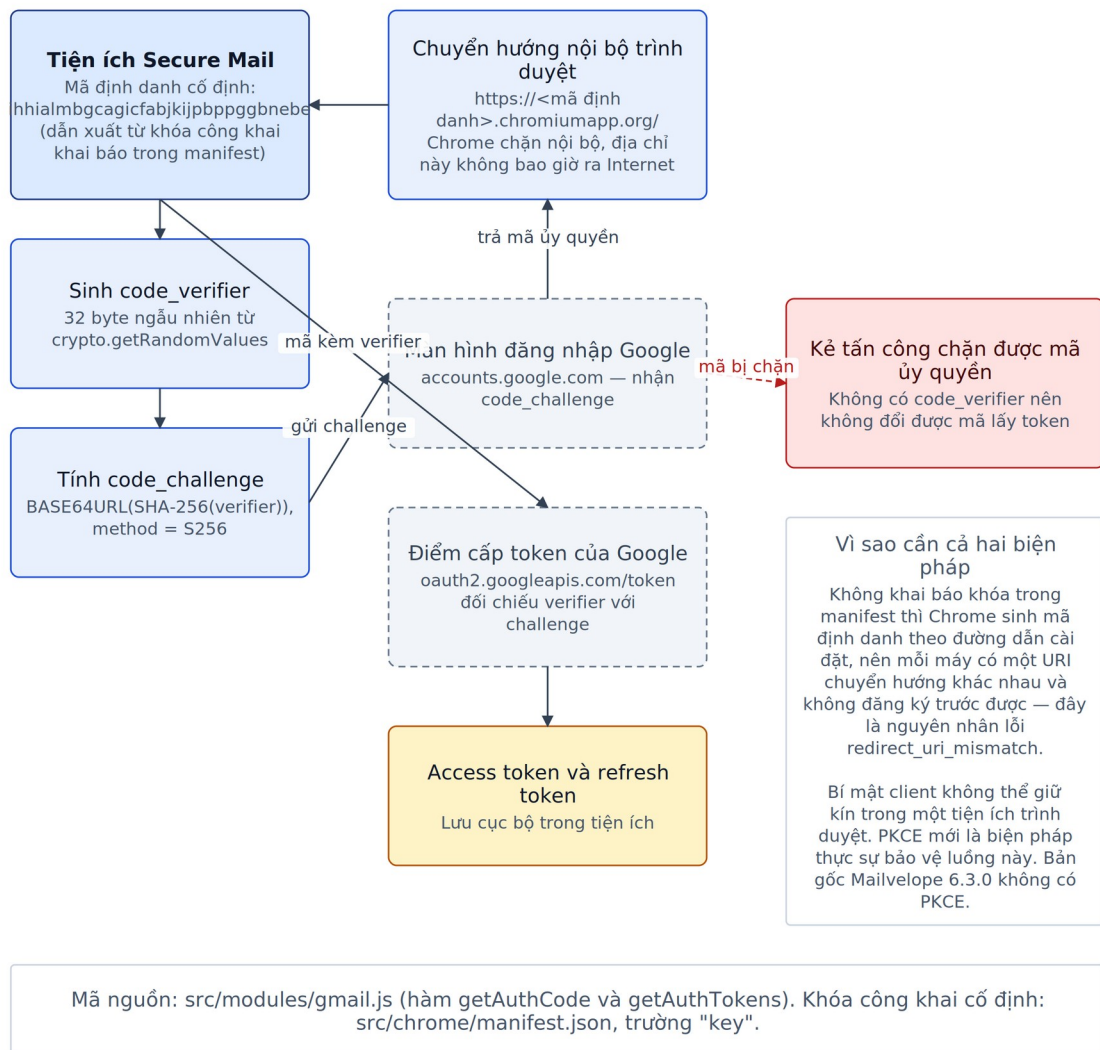
6.6.2. Vấn đề thứ hai: luồng xác thực thiếu biện pháp bảo vệ

Bản gốc ghi thẳng bí mật client vào mã nguồn. Đây không phải sơ suất mà là hệ quả bắt buộc: URI chuyển hướng dạng `chromiumapp.org` chỉ đăng ký được trên loại ứng dụng "Web application", mà Google coi loại này là ứng dụng bảo mật được và bắt buộc gửi kèm bí mật client khi đổi token.

Nhưng một tiện ích trình duyệt **không thể** giữ bí mật: toàn bộ mã được đóng gói và ai cũng đọc được. Vì vậy bí mật client ở đây không có giá trị bảo vệ thực tế.

Giải pháp: bổ sung **PKCE (RFC 7636)** với phương thức S256. Với mỗi lần xác thực, tiện ích sinh một chuỗi ngẫu nhiên 32 byte (`code_verifier`), gửi mã băm SHA-256 của nó tới màn hình đăng nhập, và chỉ gửi chuỗi gốc khi đổi mã ủy quyền lấy token. Mã ủy quyền bị gắn với một chuỗi bí mật một lần dùng, chưa từng rời khỏi tiện ích. Kẻ chặn được mã ủy quyền **không đổi được** thành token.

PKCE mới là biện pháp thực sự bảo vệ luồng này. Bản gốc Mailvelope 6.3.0 không có PKCE.

Xác thực Gmail API: định danh tiện ích cố định kết hợp PKCE (RFC 7636)

Hình 6. Luồng xác thực Gmail API với định danh cố định và PKCE

Đồng thời, bí mật client được đưa ra khỏi hệ thống quản lý phiên bản (tệp `src/modules/oauth.local.js` nằm trong danh sách loại trừ của Git, kèm tệp mẫu `oauth.local.example.js` hướng dẫn cách tạo). Việc để lộ một bí mật client trong kho mã nguồn công khai sẽ khiến nhà cung cấp tự động thu hồi và làm gián đoạn dịch vụ.

Ngoài ra, tham số `login_hint` được sửa để không mâu thuẫn với `prompt=select_account`. Bản gốc luôn gửi `login_hint`, khiến Google bỏ qua màn hình chọn tài khoản và tự động dùng tài khoản đang đăng nhập trong trình duyệt. Với máy dùng chung hoặc người dùng có nhiều tài khoản, đây là một lỗi về an toàn: người dùng có thể cấp quyền cho một tài khoản mà mình không định chọn.

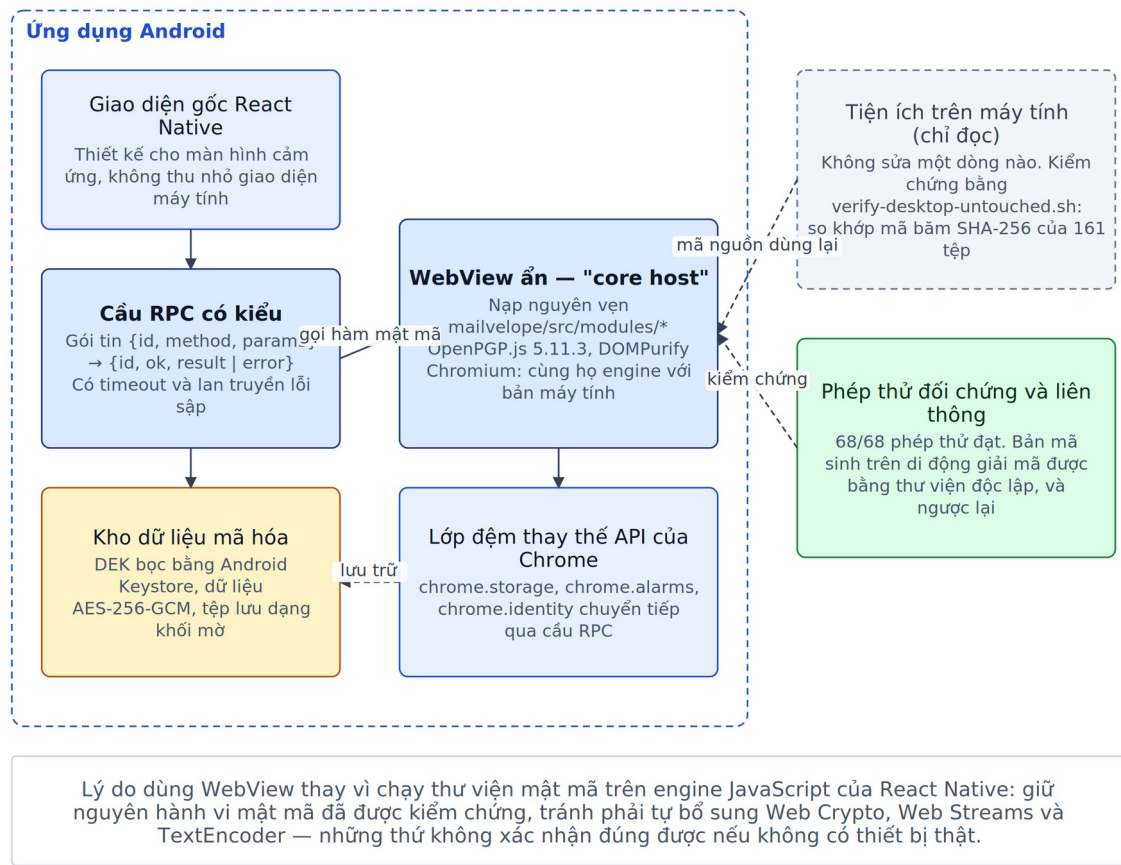
6.7. Kiến trúc mở rộng sang thiết bị di động

Tiện ích trình duyệt chỉ chạy được trên máy tính; trình duyệt trên điện thoại không hỗ trợ tiện ích mở rộng. Nếu chỉ dùng ở bản máy tính, giải pháp mất tác dụng đúng vào lúc người dùng cần nhất — khi ở ngoài cơ quan.

Bài toán đặt ra: xây dựng ứng dụng di động **mà không viết lại phần mật mã**, vì viết lại chính là điều mục 6.1 đã lập luận là phải tránh.

Giải pháp kiến trúc: giao diện gốc React Native cho phần người dùng nhìn thấy, kết hợp một **WebView ẩn** làm nơi chạy lõi mật mã, hai bên nối với nhau qua một **cầu RPC có kiểu**.

Kiến trúc phiên bản di động: tái sử dụng nguyên vẹn lõi mật mã đã kiểm chứng



Hình 7. Kiến trúc phiên bản di động

Cơ sở của lựa chọn này: WebView trên Android là Chromium — cùng họ engine với trình duyệt mà bản máy tính đang chạy. Nhờ vậy Web Crypto, Web Streams và các thành phần nền tảng khác hoạt động **giống hệt**, và mã nguồn lõi mật mã của bản

máy tính được nạp vào **nguyên vẹn, không sửa một dòng**. Nếu thay vào đó chạy thư viện mật mã trên engine JavaScript của React Native, sẽ phải tự bổ sung một loạt thành phần nền tảng còn thiếu — mỗi thành phần là một chỗ có thể sai mà không kiểm chứng được nếu không có thiết bị thật.

Ba đặc điểm kỹ thuật đáng chú ý:

Ràng buộc "không đụng vào bản máy tính" được kiểm chứng bằng máy. Bản máy tính là bản tham chiếu đang hoạt động ổn định, phải được giữ nguyên trong suốt quá trình phát triển bản di động. Ràng buộc này được bảo đảm bằng kịch bản `scripts/verify-desktop-untouched.sh`: so khớp mã băm SHA-256 của 161 tệp trong bản phát hành máy tính. Đây là cách biến một cam kết thành một phép kiểm tra tự động.

Lớp đệm (shim) thay thế API của trình duyệt. Lỗi mật mã gọi các API riêng của tiện ích Chrome (`chrome.storage`, `chrome.alarms`, `chrome.identity`). Trong WebView, các API này được thay bằng lớp đệm chuyển tiếp qua cầu RPC về phía ứng dụng gốc. Nhờ vậy lỗi không cần biết mình đang chạy ở đâu.

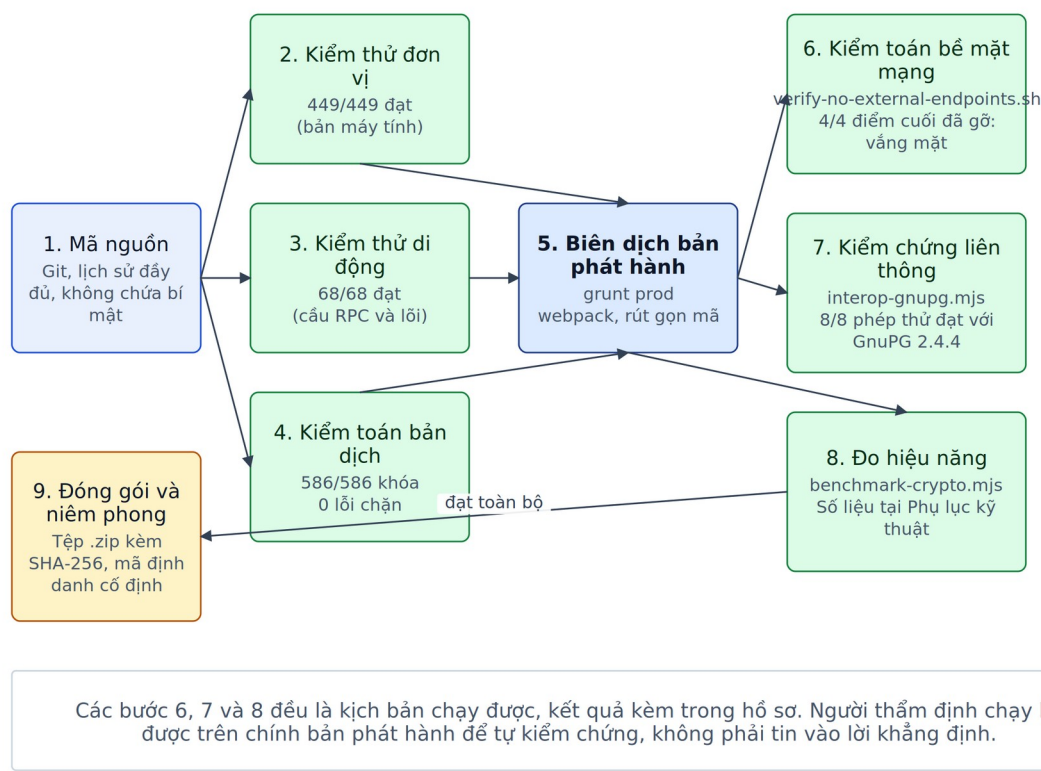
Bảo vệ dữ liệu tại chỗ. Khóa riêng tư trên điện thoại được bảo vệ bằng mã hóa lồng: một khóa mã hóa dữ liệu (DEK) được bọc bằng Android Keystore, dữ liệu được mã hóa AES-256-GCM, tệp lưu trên máy chỉ là khối dữ liệu không diễn giải được.

Trạng thái hiện tại: **hoàn thành phần nền tảng** — cầu RPC, lớp đệm, các bộ xử lý cho chòm khóa, mã hóa, sao lưu, tùy chọn; **68/68 phép thử tự động đạt**, trong đó có các phép thử đối chứng chứng minh bản mã sinh ra ở bản di động giải mã được bằng thư viện độc lập và ngược lại. Phần giao diện người dùng và tích hợp Gmail trên di động là công việc của giai đoạn tiếp theo (mục 13).

6.8. Quy trình xây dựng và kiểm chứng

Nguyên tắc xuyên suốt: **mọi khẳng định về an toàn phải có một lệnh chạy được để kiểm tra lại.**

Quy trình xây dựng và kiểm chứng một bản phát hành



Hình 8. Quy trình xây dựng và kiểm chứng một bản phát hành

Bộ công cụ kiểm chứng gồm năm kịch bản, tất cả đều kèm theo hồ sơ:

Bảng 8. Bộ công cụ kiểm chứng đi kèm sản phẩm

Kịch bản	Kiểm tra điều gì	Kết quả trên bản v0.3.0
scripts/verify-no-external-endpoints.sh	Các điểm cuối đã gỡ không xuất hiện trở lại trong gói phát hành; liệt kê toàn bộ bề mặt mạng còn lại	ĐẠT — 4/4
scripts/interop-gnupg.mjs	Bản mã và chữ ký liên thông hai chiều với GnuPG; phát hiện được bản mã bị sửa	ĐẠT — 8/8
scripts/benchmark-crypto.mjs	Đo thời gian sinh khóa, mã hóa, giải mã và độ giãn nở bản mã	Số liệu tại Bảng 10, Bảng 11
scripts/verify-translation.mjs	Độ phủ, ô thay thế, thẻ đánh dấu, nhất quán thuật ngữ của bản dịch	ĐẠT — 586/586, 0 lỗi chặn
mobile/scripts/verify-desktop-untouched.sh	Bản máy tính không bị thay đổi trong quá trình phát triển bản di động	ĐẠT — 161/161 tệp khớp mã băm

Bổ sung hai kịch bản phục vụ tài liệu hóa: `scripts/capture-screenshots.mjs` và `scripts/capture-workflow.mjs` nạp **chính gói phát hành** vào trình duyệt và chụp lại giao diện. Nhờ vậy mọi ảnh chụp trong hồ sơ này đều là ảnh của sản phẩm thật, tái tạo lại được, không phải bản dựng minh họa.

Bản phát hành được niêm phong bằng mã băm SHA-256, cho phép người nhận kiểm tra tính toàn vẹn của gói cài đặt trước khi dùng.

6.9. Kiểm soát rủi ro của việc dùng phần mềm nguồn mở nước ngoài làm nền

Một câu hỏi chính đáng: *dùng phần mềm nguồn mở của nước ngoài làm nền có an toàn không?*

Trả lời phải bắt đầu từ việc so sánh đúng đối tượng. Lựa chọn thực tế không phải giữa "phần mềm nguồn mở nước ngoài" và "phần mềm trong nước", mà giữa **phần mềm đọc được mã nguồn** và **phần mềm hộp đen**. Với một sản phẩm an toàn thông tin, khả năng đọc được mã nguồn là **ưu điểm quyết định**: mọi khẳng định trong hồ sơ này sở dĩ kiểm chứng được là vì mã nguồn mở ra để đọc. Không có điều đó thì không thể chứng minh rằng thư viện đo lường từ xa đã được gỡ bỏ, cũng không thể phát hiện ra rằng nó từng tồn tại.

Bốn biện pháp kiểm soát rủi ro đã được áp dụng:

Đóng băng phiên bản, không tự động cập nhật. Mã nguồn được sao chép tại một mốc xác định (commit `ffaa27af`, nhãn `v6.3.0`) và **không đồng bộ tiếp** với thượng nguồn. Nguồn gốc được ghi trong `SOURCE_SNAPSHOT.md` kèm chính sách này. Mọi thay đổi từ thượng nguồn về sau, nếu muốn tiếp nhận, đều phải qua rà soát chủ động chứ không tự động chảy vào sản phẩm.

Khóa chặt chuỗi cung ứng phụ thuộc. Phiên bản của mọi thư viện phụ thuộc được ghim bằng `package-lock.json` và cài bằng `npm ci` (cài đúng theo tệp khóa) chứ không phải `npm install`. Chính sách của dự án ghi rõ không chạy các lệnh làm thay đổi tệp khóa, để đầu vào của quá trình biên dịch không đổi giữa các lần dựng.

Rà soát và cắt bỏ những gì không cần thiết. Toàn bộ mục 6.5 là kết quả của việc rà soát này: hai kênh liên lạc ra bên thứ ba đã bị gỡ khỏi mã nguồn, và việc gỡ được kiểm chứng trên gói phát hành.

Kiểm chứng bằng bên thứ ba độc lập. Phép thử liên thông không dùng công cụ của tác giả để chấm bài của chính tác giả: **GnuPG là phần mềm độc lập hoàn toàn về mã nguồn và về tổ chức phát triển.** Việc GnuPG đọc được đúng bản mã và xác minh đúng chữ ký là bằng chứng do một bên ngoài đưa ra.

Cần nói thêm về lỗi mật mã: OpenPGP.js là thư viện được cộng đồng soi xét trong nhiều năm, đã qua đánh giá an toàn độc lập và được nhiều sản phẩm sử dụng. Việc thay nó bằng một thư viện tự viết để "tự chủ hơn" sẽ **làm giảm** độ an toàn thực tế, vì một thư viện mật mã mới chưa qua thời gian soi xét là thứ rủi ro nhất trong toàn hệ thống. Đây là lý do của kỷ luật nêu ở mục 6.1.

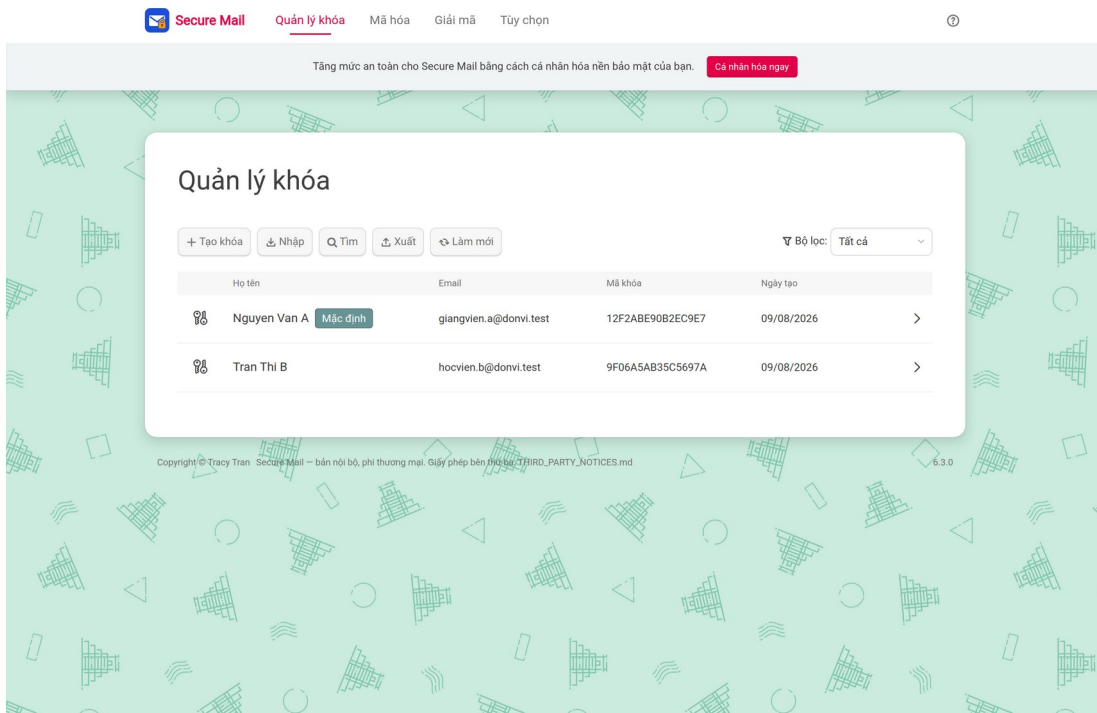
7. Kết quả của giải pháp

7.1. Sản phẩm hoàn chỉnh

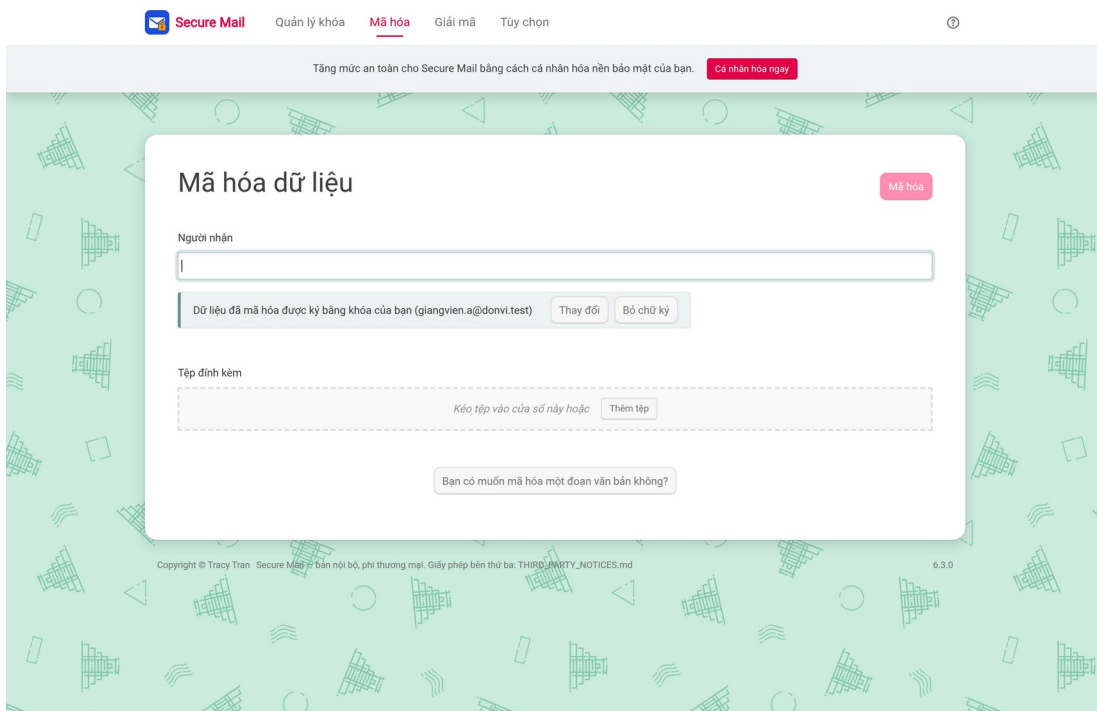
Bảng 9. Sản phẩm bàn giao

Hạng mục	Nội dung
Tiện ích trình duyệt	Secure Mail v0.3.0, Manifest V3, cho Chrome/Edge từ phiên bản 122
Mã định danh tiện ích	ihhialmbgcagicfabjkijsbpbppggbnebe (cố định trên mọi máy)
Gói cài đặt	secure-mail-v0.3.0-hardened.zip, 2,9 MB
Mã băm SHA-256 của gói	775bed7407df03b9c1f845300e2020e8f5d292e289419d6a8e65e7576558b106
Lỗi mật mã	OpenPGP.js 5.11.3, không sửa đổi
Ngôn ngữ giao diện	Tiếng Việt và tiếng Anh, người dùng chọn được; 14 ngôn ngữ khác của bản gốc vẫn hoạt động
Dự án phiên bản di động	Kho mobile/ — nền tảng hoàn chỉnh, 68/68 phép thử đạt
Tài liệu vận hành tiếng Việt	9 tài liệu: hướng dẫn cài đặt, hướng dẫn người dùng, quy trình quản lý khóa công khai, quy trình phát hành, danh mục kiểm tra an toàn, danh mục kiểm thử
Bộ công cụ kiểm chứng	5 kịch bản, 637 dòng (thêm 2 kịch bản chụp ảnh tài liệu, 275 dòng)

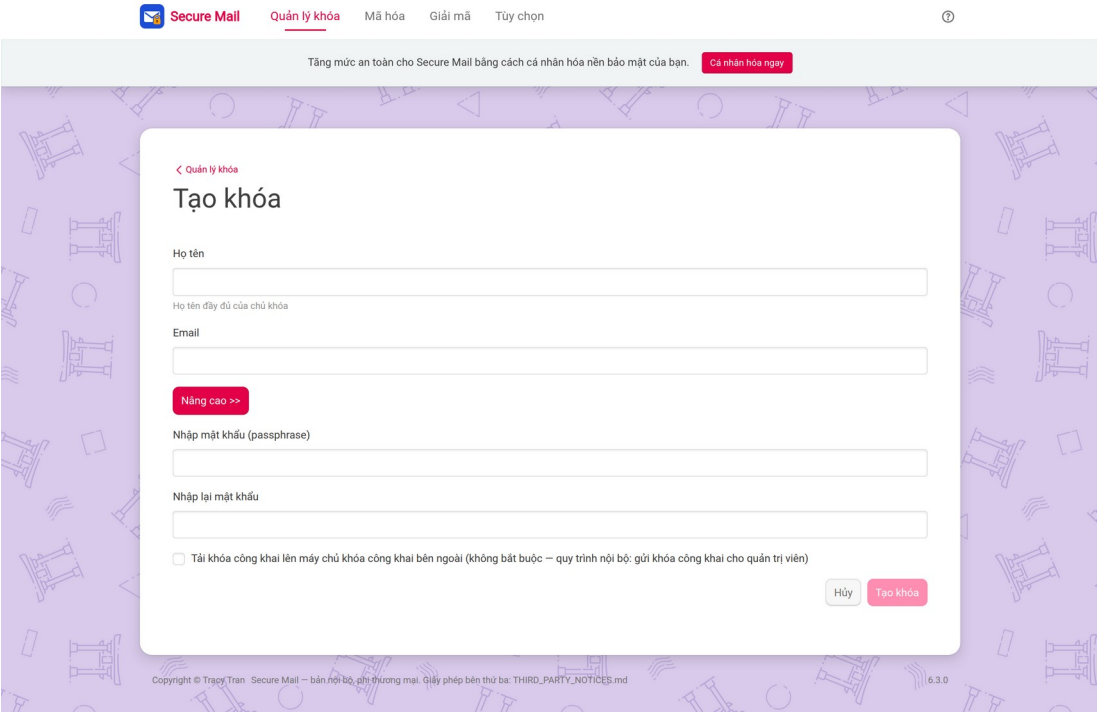
Ba hình dưới đây chụp trực tiếp từ gói phát hành v0.3.0 bằng kịch bản `scripts/capture-workflow.mjs`, sau khi kịch bản này tự động sinh hai cặp khóa RSA-4096 thật qua giao diện. Không có hình nào là bản dựng minh họa.



Hình 9. Màn hình Quản lý khóa với hai cặp khóa RSA-4096 được sinh thật trong quá trình kiểm thử



Hình 10. Màn hình Mã hóa dữ liệu: mặc định ký bằng khóa của người gửi, hỗ trợ mã hóa cả tệp đính kèm



Hình 11. Màn hình Tạo khóa bằng tiếng Việt; ghi chú dưới ô chọn nêu rõ quy trình nội bộ là gửi khóa công khai cho quản trị viên

7.2. Kết quả kiểm thử chức năng

Bảng dưới đây ghi rõ **phép thử nào kế thừa và phép thử nào do tác giả xây dựng**. Sự phân biệt này quan trọng: hai loại chứng minh hai điều khác nhau, và gộp chung lại sẽ làm sai lệch cách đánh giá.

Bảng 10. Kết quả các bộ kiểm thử tự động, phân theo nguồn gốc

Bộ kiểm thử	Nguồn gốc	Chứng minh điều gì	Kết quả
Kiểm thử đơn vị bản máy tính — 22 nhóm, bao trùm giao diện, bộ điều khiển, các mô-đun lỗi	Kế thừa từ bản gốc (29 tệp kiểm thử, tác giả sửa 3 phép thử)	Việc cải tạo không phá vỡ chức năng sẵn có — đây là giá trị chính của chúng	449/449 đạt
Kiểm thử bản di động — cầu RPC, lớp đệm, chòm khóa, mã hóa, sao lưu, phép thử đối chứng và liên thông	Do tác giả xây dựng hoàn toàn (10 tệp)	Lỗi mật mã chạy trên kiến trúc mới cho kết quả tương đương bản máy tính	68/68 đạt
Kiểm chứng liên thông với GnuPG	Do tác giả xây dựng	Bản mã là OpenPGP chuẩn, đọc được bằng phần mềm độc lập	8/8 đạt
Kiểm toán bề mặt mạng gói phát hành	Do tác giả xây dựng	Các điểm cuối bên thứ ba đã bị gỡ, không xuất hiện trở lại	4/4 vắng mặt

Kiểm toán bản dịch — 586 chuỗi, 5 nhóm lỗi	Do tác giả xây dựng	Bản dịch đầy đủ, không mất ô thay thế, thuật ngữ nhất quán	0 lỗi chặn
Kiểm chứng bản máy tính không bị thay đổi	Do tác giả xây dựng	161 tệp của bản phát hành khớp mã băm	161/161 khớp
Tổng			Không có phép thử nào thất bại

Nói rõ để tránh hiểu nhầm: **449 phép thử đơn vị của bản máy tính là kế thừa**, không phải công sức của tác giả. Giá trị của chúng trong hồ sơ này là bằng chứng **không hồi quy**: sau khi gỡ bỏ thư viện đo lường, gỡ cơ chế kiểm tra giấy phép, thay lớp đa ngữ và sửa luồng xác thực, toàn bộ chức năng sẵn có vẫn hoạt động đúng. Đó là điều cần chứng minh khi cải tạo một hệ thống đang chạy, và chỉ một bộ kiểm thử kế thừa mới chứng minh được — chính vì nó không do người cải tạo viết ra.

Ba phép thử trong bộ này đã thất bại trước khi hoàn thiện hồ sơ, do vẫn còn kiểm tra tên và địa chỉ của sản phẩm gốc sau khi đổi nhận diện. Đây là nợ kỹ thuật thực sự — một bộ kiểm thử không chạy trọn vẹn thì mất giá trị bảo đảm, vì lỗi mới sẽ lẫn vào những lỗi đã biết — và đã được sửa.

7.3. Kết quả kiểm chứng tính liên thông

Giá trị của giải pháp phụ thuộc vào việc bản mã của nó là **OpenPGP chuẩn**, không phải một định dạng riêng. Thư mã hóa hôm nay phải đọc được bằng bất kỳ phần mềm tuân thủ chuẩn nào, trên bất kỳ nền tảng nào, kể cả khi bản thân Secure Mail không còn được dùng. Đây là điều kiện để dữ liệu của đơn vị không bị khóa vào một sản phẩm.

Kịch bản `scripts/interop-gnupg.mjs` chứng minh điều này bằng cách trao đổi thư thật hai chiều với **GnuPG 2.4.4** — phần mềm mật mã tham chiếu, độc lập hoàn toàn về mã nguồn.

Bảng 11. Kết quả kiểm chứng liên thông với GnuPG 2.4.4

Phép thử	Nội dung	Kết quả
Nhập khóa (Secure Mail → GnuPG)	GnuPG chấp nhận khóa công khai RSA-4096 do Secure Mail sinh	ĐẠT
Nhập khóa (GnuPG → Secure Mail)	Secure Mail đọc và phân tích được khóa do GnuPG sinh	ĐẠT

A. Tính bí mật (Secure Mail → GnuPG)	GnuPG khôi phục bản rõ đúng từng byte, tiếng Việt có dấu nguyên vẹn	ĐẠT
A. Tính xác thực (Secure Mail → GnuPG)	GnuPG báo chữ ký hợp lệ (GOODSIG)	ĐẠT
B. Tính bí mật (GnuPG → Secure Mail)	Secure Mail khôi phục bản rõ đúng từng byte	ĐẠT
B. Tính xác thực (GnuPG → Secure Mail)	Secure Mail xác minh đúng chữ ký của GnuPG	ĐẠT
C. Chữ ký tách rời	GnuPG xác minh được chữ ký tách rời do Secure Mail tạo	ĐẠT
D. Tính toàn vẹn	Đổi một ký tự trong bản mã: bị từ chối, không trả về bản rõ sai	ĐẠT
Tổng		8/8 ĐẠT

Phép thử D đáng chú ý về mặt phương pháp: nó chứng minh một **thuộc tính an toàn tiêu cực** — hệ thống từ chối dữ liệu bị sửa đổi thay vì âm thầm cho ra kết quả sai. Với một hệ thống mật mã, thất bại đúng cách quan trọng ngang thành công đúng cách.

Nội dung dùng để thử là văn bản tiếng Việt có dấu, nên phép thử đồng thời xác nhận đường xử lý UTF-8 không bị hỏng khi đi qua một phần mềm khác.

7.4. Kết quả đo hiệu năng

Đo bằng scripts/benchmark-crypto.mjs trên máy chủ xây dựng (AMD EPYC, 4 nhân, 7,8 GB RAM), dùng đúng thư viện OpenPGP.js 5.11.3 mà bản phát hành đóng gói. Mỗi giá trị là **trung vị** của nhiều lần chạy.

Bảng 12. Thời gian sinh cặp khóa

Loại khóa	Trung vị	Các lần đo
RSA-2048	428 ms	564 / 428 / 362 ms
RSA-4096 (mặc định của sản phẩm)	2.785 ms	3.153 / 1.708 / 2.785 ms
ECC Curve25519	306 ms	348 / 254 / 306 / 318 / 247 ms

Đo bổ sung **trên chính giao diện của bản phát hành**, chạy trong trình duyệt thật: sinh khóa RSA-4096 hoàn tất sau **10,2 giây** và **8,1 giây** cho hai lần. Con số này lớn hơn phép đo thư viện thuần vì bao gồm cả xử lý giao diện, truyền tin giữa các

thành phần và ghi vào kho lưu trữ. Đây là **thời gian người dùng thực sự chờ**, và là thao tác chỉ thực hiện một lần khi thiết lập ban đầu.

Bảng 13. Thời gian mã hóa kèm ký và giải mã kèm xác minh

Kích thước dữ liệu	Mã hóa + ký	Giải mã + xác minh	Độ giãn nở bản mã
Thư điện tử tiêu biểu (tiếng Việt, ~5 KB)	36 ms	19 ms	+88%
1 KB	15 ms	19 ms	+197%
10 KB	16 ms	15 ms	+52%
100 KB	34 ms	47 ms	+37%
1 MB	115 ms	26 ms	+36%
5 MB (tệp đính kèm lớn)	404 ms	87 ms	+36%

Nhận xét về kết quả:

- **Với thư điện tử thông thường, độ trễ do mã hóa là 15–36 mili giây** — nằm dưới ngưỡng cảm nhận của con người. Người dùng không thấy sản phẩm chậm đi.
- **Với tệp đính kèm 5 MB, tổng thời gian dưới nửa giây.** Không phải là trở ngại trong sử dụng thực tế.
- Độ giãn nở bản mã ổn định ở mức **khoảng 36%** với dữ liệu lớn. Đây là hệ quả của mã hóa Base64 (bản thân đã làm tăng 33%) để khối bản mã đi qua được hệ thống thư điện tử vốn chỉ bảo đảm truyền văn bản. Với dữ liệu nhỏ, tỷ lệ cao hơn vì phần tiêu đề cố định chiếm tỷ trọng lớn. Các phép đo trên dùng dữ liệu ngẫu nhiên không nén được, nên đây là **trường hợp xấu nhất**; thư văn bản thật nén được nhiều hơn.
- Cần lưu ý khi đọc bảng: tệp đính kèm 5 MB sau khi mã hóa thành khoảng 6,8 MB, vẫn nằm trong hạn mức 25 MB của Gmail.

7.5. Kết quả về bản địa hóa

Bảng 14. Độ phủ bản dịch so với các ngôn ngữ khác của sản phẩm gốc

Ngôn ngữ	Số chuỗi	Độ phủ so với tiếng Anh (586 chuỗi)
Tiếng Việt (sáng kiến này)	586	100%
Tiếng Đức	579	98,8%
Tiếng Ukraina	534	91,1%
Tiếng Pháp	534	91,1%

Tiếng Thổ Nhĩ Kỳ	533	91,0%
Tiếng Ả Rập	531	90,6%
Tiếng Nga	530	90,4%
Tiếng Nhật	528	90,1%
Tiếng Khmer	512	87,4%
Tiếng Tây Ban Nha	489	83,4%

Tiếng Việt là ngôn ngữ **duy nhất đạt độ phủ 100%** ngoài tiếng Anh. Đây không phải con số để so bì mà là một chỉ tiêu chất lượng có ý nghĩa thực tế: bất kỳ chuỗi nào thiếu đều rơi về tiếng Anh, và với người dùng không thạo tiếng Anh thì một thông báo lỗi bằng tiếng Anh xuất hiện đúng lúc gặp sự cố là lúc tệ nhất.

PHẦN III. TỰ ĐÁNH GIÁ GIẢI PHÁP

8. Tính mới

Trước khi liệt kê, cần trả lời thẳng câu hỏi mà một hội đồng nghiêm khắc chắc chắn sẽ đặt ra:

"Đây có phải chỉ là dịch giao diện một phần mềm nguồn mở sang tiếng Việt hay không?"

Không. Bản dịch là một trong năm điểm mới, và ngay cả nó cũng đòi hỏi phải sửa kiến trúc lớp đa ngữ trước thì mới thực hiện được. Bốn điểm còn lại — chuyển mô hình tin cậy, cắt bỏ phụ thuộc bên thứ ba, làm luồng xác thực an toàn và triển khai được, mở rộng sang di động — là công việc kỹ thuật trên mã nguồn, ảnh hưởng trực tiếp tới thuộc tính an toàn của sản phẩm, và **không thể thực hiện bằng cách dịch**.

Điểm mới 1 — Trình khách OpenPGP hoàn chỉnh bằng tiếng Việt, kèm bộ thuật ngữ chuẩn hóa

Theo khảo sát tại mục 3, chưa có trình khách mã hóa thư điện tử đầu cuối nào có giao diện tiếng Việt hoàn chỉnh: Mailvelope 15 ngôn ngữ không có tiếng Việt; FlowCrypt không có cơ chế đa ngữ; Proton Mail và Tuta không có tiếng Việt. Sáng kiến tạo ra bản dịch **586/586 chuỗi, độ phủ 100%**, kèm **bộ thuật ngữ mật mã tiếng Việt được chuẩn hóa và kiểm tra nhất quán bằng công cụ**.

Đóng góp không dừng ở phần mềm. Bộ thuật ngữ tại Bảng 5 là kết quả của việc cân nhắc từng khái niệm theo tiêu chí sư phạm — ví dụ chọn "khóa riêng tư" thay vì "khóa bí mật" để tránh nhầm lẫn với "bí mật nhà nước", hay giữ từ gốc trong ngoặc ở lần xuất hiện đầu để người học nối được với tài liệu tiếng Anh. Bộ thuật ngữ này dùng lại được cho bài giảng, giáo trình và các phần mềm khác.

Điểm mới 2 — Cơ chế chọn ngôn ngữ vượt qua giới hạn kiến trúc của nền tảng

Bản gốc, cũng như phần lớn tiện ích trình duyệt, khóa cứng ngôn ngữ theo trình duyệt. Sáng kiến thay lớp phân giải chuỗi bằng một bộ phân giải hai danh mục có cơ chế lùi bốn bước, cho phép người dùng chọn ngôn ngữ độc lập với trình duyệt **mà không phá vỡ** cơ chế đa ngữ sẵn có cho 14 ngôn ngữ còn lại.

Đây là điểm mới về kỹ thuật, không phải về nội dung. Nó giải quyết một ràng buộc kiến trúc, và là **điều kiện cần** để bản dịch tiếng Việt có tác dụng trong thực tế.

Điểm mới 3 — Chuyển mô hình tin cậy sang mô hình khép kín do đơn vị kiểm soát

Sáng kiến thay mô hình "tra cứu máy chủ khóa công cộng ở nước ngoài, tin theo TOFU" bằng mô hình "phân phối khóa khép kín, xác nhận danh tính qua kênh nội bộ đã xác thực", kèm quy trình quản trị được tài liệu hóa và mẫu danh mục khóa.

Đây là thay đổi về **mô hình an toàn**, không phải về cấu hình. Nó loại bỏ một kênh rò rỉ siêu dữ liệu quan hệ liên lạc và đặt trách nhiệm xác nhận danh tính vào đúng chỗ — nơi có thẩm quyền và có quy trình để làm.

Điểm mới 4 — Loại bỏ triệt để phụ thuộc bên thứ ba, kiểm chứng được trên gói phát hành

Sáng kiến gỡ bỏ khỏi mã nguồn hai kênh liên lạc ra bên thứ ba mà người dùng không nhận biết và không tắt được bằng cấu hình: thư viện đo lường từ xa và cơ chế kiểm tra giấy phép thương mại. Kết quả là sản phẩm ở cấu hình mặc định **không liên lạc với máy chủ nào ngoài chính Gmail**, và điều đó **kiểm tra lại được bằng một lệnh** trên gói phát hành.

Riêng việc gỡ cơ chế kiểm tra giấy phép còn có ý nghĩa về tính sẵn sàng: nó **mở khóa khả năng sử dụng cho tài khoản Google Workspace** — chính là loại tài khoản mà một cơ quan sẽ dùng, và là trường hợp bị bản gốc chặn.

Điểm mới 5 — Kiến trúc mở rộng sang di động giữ nguyên lõi mật mã đã kiểm chứng

Cách làm thông thường khi đưa một ứng dụng mật mã lên di động là viết lại phần mật mã bằng thư viện của nền tảng — kéo theo rủi ro sai lệch hành vi mà không kiểm chứng được. Sáng kiến chọn kiến trúc "giao diện gốc + WebView chạy lõi mật mã + cầu RPC có kiểu", nạp mã nguồn lõi **nguyên vẹn không sửa một dòng**, và chứng minh sự tương đương bằng bộ phép thử đối chứng.

Kèm theo là kỹ thuật biến ràng buộc "không được đụng vào bản đang chạy ổn định" thành một phép kiểm tra tự động bằng mã băm 161 tệp — một cách làm áp dụng được cho mọi dự án cải tạo hệ thống đang vận hành.

9. Tính sáng tạo

Tính mới nói về *cái gì* đã được tạo ra. Tính sáng tạo nói về *cách* đi tới đó. Bốn điểm dưới đây là những lựa chọn phương pháp mà tác giả cho là phần đóng góp có giá trị lâu dài nhất.

9.1. Biến khẳng định an toàn thành phép kiểm tra chạy lại được

Trong tài liệu về sản phẩm bảo mật, những câu như "không thu thập dữ liệu người dùng", "không gửi thông tin ra bên ngoài", "mã hóa đầu cuối" xuất hiện thường xuyên và gần như không bao giờ kiểm chứng được. Người đọc chỉ có thể tin hoặc không tin.

Sáng kiến áp dụng một nguyên tắc khác: **mỗi khẳng định phải đi kèm một lệnh để bác bỏ nó.**

- "Không có đo lường từ xa" → chạy `verify-no-external-endpoints.sh`, xem 0 lần xuất hiện trên gói phát hành.
- "Bản mã là OpenPGP chuẩn" → chạy `interop-gnupg.mjs`, xem GnuPG đọc được.
- "Nhanh, không ảnh hưởng thao tác" → chạy `benchmark-crypto.mjs`, xem con số.
- "Dịch đầy đủ và nhất quán" → chạy `verify-translation.mjs`, xem báo cáo.
- "Không đụng vào bản đang chạy" → chạy `verify-desktop-untouched.sh`, xem 161 mã băm.
- "Ảnh chụp là sản phẩm thật" → chạy `capture-screenshots.mjs`, tự chụp lại.

Cách làm này đảo ngược gánh nặng chứng minh: người thẩm định không phải tin tác giả, mà **tự kiểm tra được**. Phương pháp này áp dụng được cho bất kỳ hồ sơ sản phẩm an toàn thông tin nào và, theo đánh giá của tác giả, có giá trị vượt ra ngoài phạm vi sáng kiến này.

Chính phương pháp đó đã tự phát hiện lỗi trong sản phẩm: sáu lỗi dịch thuật (hai trong đó làm mất khuyến cáo an toàn) và ba phép thử hỏng. Một quy trình chỉ tìm thấy điều tốt đẹp là một quy trình không hoạt động.

9.2. Kỷ luật "không sửa cái không cần sửa"

Cám dỗ lớn trong một sáng kiến kỹ thuật là làm nhiều để có vẻ đóng góp nhiều. Với phần mềm mật mã, đó là hướng sai.

Sáng kiến áp dụng một ranh giới rõ ràng: **thay đổi mọi thứ cản trở việc triển khai; không đụng vào lỗi mật mã đã được kiểm chứng**. OpenPGP.js 5.11.3 được giữ nguyên. Các thuật toán được giữ nguyên. Định dạng dữ liệu được giữ nguyên — và chính vì thế phép thử liên thông với GnuPG mới đạt 8/8.

Kỷ luật này được ghi thành quy tắc bắt buộc trong tài liệu dự án ("không sửa lỗi mật mã trừ khi thật sự cần thiết và đã được rà soát") và được bảo đảm bằng kiểm tra mã băm ở phần di động.

9.3. Chọn đúng biện pháp cho đúng mô hình đe dọa

Vấn đề bí mật client trong tiện ích trình duyệt minh họa rõ cách tiếp cận này. Phản xạ thông thường khi thấy một bí mật nằm trong mã nguồn là tìm cách giấu nó kỹ hơn — làm rối mã, tách ra tệp riêng, mã hóa. Tất cả đều vô ích: mã của tiện ích luôn đọc được.

Phân tích đúng phải bắt đầu từ câu hỏi *biện pháp này bảo vệ chống lại điều gì*. Bí mật client tồn tại để chứng minh danh tính ứng dụng — điều mà một tiện ích trình duyệt về nguyên tắc không làm được. Vì vậy giải pháp không phải là giấu nó kỹ hơn, mà là **bổ sung một biện pháp khác thực sự phù hợp**: PKCE, gắn mã ủy quyền với một bí mật một lần dùng chưa từng rời khỏi tiện ích.

Cùng cách tiếp cận đó dẫn tới quyết định gỡ bỏ hẳn thay vì tắt bằng cấu hình ở mục 6.5: nếu mô hình đe dọa bao gồm cả một lần cập nhật vô ý từ thượng nguồn, thì một hằng số `false` không phải là biện pháp bảo vệ.

9.4. Dùng chính sản phẩm làm học cụ

Với vai trò giảng viên, tác giả thiết kế phần bản địa hóa theo tiêu chí sư phạm chứ không chỉ theo tiêu chí dịch thuật:

- **Thuật ngữ song ngữ có chủ đích.** Lần đầu xuất hiện, một khái niệm được viết "dấu vân tay (fingerprint)" — người học hiểu ngay, đồng thời nổi được với tài liệu chuyên môn tiếng Anh.
- **Cảnh báo an toàn nằm ngay trong giao diện.** Ba nguyên tắc cốt lõi — không bao giờ chia sẻ khóa riêng tư; quản trị viên chỉ giữ khóa công khai; mất khóa mà không có bản sao lưu thì thư cũ không đọc lại được — được đưa vào chính màn hình thiết lập, bằng tiếng Việt, thay vì để trong tài liệu mà không ai đọc.
- **Sản phẩm dùng thật cũng là bài thực hành.** Người học sinh khóa, đối chiếu dấu vân tay, gửi thư mã hóa, cố ý sửa một ký tự trong bản mã để thấy hệ thống từ chối. Những thao tác trừu tượng trên bảng trở thành thao tác nhìn thấy được.

10. Khả năng áp dụng

10.1. Điều kiện triển khai

Rào cản triển khai được giữ ở mức thấp nhất có thể — đây là một mục tiêu thiết kế, không phải may mắn:

- **Hạ tầng:** không cần. Không máy chủ, không hệ thống chứng thực số, không thay đổi hệ thống thư điện tử hiện có.
- **Phần mềm:** trình duyệt Chrome hoặc Edge từ phiên bản 122 — đã có sẵn trên hầu hết máy trạm.
- **Cài đặt:** giải nén gói và nạp vào trình duyệt; có hướng dẫn tiếng Việt kèm ảnh minh họa.
- **Nhân sự:** một quản trị viên khóa cho mỗi đơn vị, làm nhiệm vụ đối chiếu dấu vân tay và phát hành danh mục khóa công khai. Không đòi hỏi trình độ chuyên gia mật mã; quy trình đã được tài liệu hóa từng bước.
- **Đào tạo người dùng:** ước tính khoảng một buổi, dựa trên số bước thao tác thực tế mà người dùng cần nắm (sinh khóa, sao lưu khóa, nhập khóa người nhận, gửi và đọc thư mã hóa). Con số này **chưa được kiểm chứng qua đào tạo thực tế** và cần được xác nhận khi triển khai.

10.2. Đối tượng áp dụng

Nhóm 1 — Phục vụ giảng dạy và học tập. Đây là nhóm sẵn sàng áp dụng ngay, vì môi trường đã sẵn có và không có rào cản pháp lý.

- Giảng dạy học phần An toàn thông tin, Mật mã ứng dụng, An ninh mạng: dùng làm học cụ thực hành mật mã khóa công khai, chữ ký số, quản lý khóa, mô hình tin cậy.
- Bảo vệ tài liệu giảng dạy khi trao đổi qua thư điện tử: đề cương, đề thi chưa công bố, đáp án, kết quả học tập.
- Hướng dẫn đồ án, luận văn: trao đổi bản thảo chưa công bố.

Nhóm 2 — Trao đổi nghiệp vụ nội bộ. Áp dụng cho thông tin cần bảo vệ nhưng không thuộc danh mục bí mật nhà nước, theo quy chế của đơn vị.

Nhóm 3 — Nghiên cứu khoa học. Trao đổi dữ liệu nghiên cứu, bản thảo, kết quả chưa công bố giữa các nhóm nghiên cứu.

Nhóm 4 — Nhân rộng. Vì không đòi hỏi hạ tầng, giải pháp áp dụng được ở các nhà trường, học viện, cơ quan khác có nhu cầu tương tự. Mã nguồn, tài liệu và bộ thuật ngữ đều dùng lại được.

10.3. Giới hạn của khả năng áp dụng

Trình bày rõ để tránh kỳ vọng sai:

- **Chỉ có tác dụng khi cả hai đầu cùng dùng.** Mã hóa đầu cuối đòi hỏi người nhận cũng có công cụ và khóa. Người nhận có thể dùng bất kỳ phần mềm OpenPGP nào (đã chứng minh liên thông với GnuPG), nhưng không thể là người không dùng gì.
- **Chưa bảo vệ siêu dữ liệu.** Người gửi, người nhận, thời gian, kích thước và tiêu đề thư vẫn hiển thị với nhà cung cấp. Đây là giới hạn của bản thân giao thức thư điện tử, không phải của sản phẩm; mọi giải pháp mã hóa thư điện tử hiện có đều chia sẻ giới hạn này.
- **Chưa có ứng dụng di động hoàn chỉnh.** Phần nền tảng đã xong và kiểm chứng được; phần giao diện là công việc giai đoạn tiếp theo.
- **Ràng buộc pháp lý về phạm vi dữ liệu.** Trình bày tại mục 12.

11. Hiệu quả

11.1. Hiệu quả kỹ thuật

Đây là nhóm hiệu quả đã đo được, so sánh trực tiếp với bản gốc mà sáng kiến kế thừa.

Bảng 15. So sánh chỉ tiêu kỹ thuật trước và sau cải tạo

Chỉ tiêu	Bản gốc Mailvelope 6.3.0	Secure Mail v0.3.0	Ý nghĩa
Ngôn ngữ tiếng Việt	Không có	586/586 chuỗi, 100%	Dùng được không cần tiếng Anh
Người dùng chọn ngôn ngữ	Không (khóa theo trình duyệt)	Có, 3 lựa chọn	Không phụ thuộc cấu hình trình duyệt
Tra cứu máy chủ khóa bên ngoài	3 cơ chế bật mặc định	4 cơ chế tắt mặc định	Không rò rỉ quan hệ liên lạc
Thư viện đo lường từ xa trong gói	Có (9 lần xuất hiện)	Không có (0)	Không có kênh thu thập dữ liệu
Kiểm tra giấy phép gọi ra bên thứ ba	Có	Không có (0)	Tài khoản Workspace dùng được; không phụ thuộc dịch vụ thương mại
PKCE bảo vệ luồng xác thực	Không	Có (S256, RFC 7636)	Mã ủy quyền bị chặn không dùng được
Định danh tiện ích	Thay đổi theo máy	Cố định	Triển khai được; kiểm chứng được bản cài
Bộ công cụ kiểm chứng đi kèm	Không	5 kịch bản	Khắc định an toàn kiểm tra lại được
Kiến trúc di động	Không	Nền tảng hoàn chỉnh, 68/68 đạt	Mở đường cho giai đoạn 2
Liên thông OpenPGP chuẩn	Có	Có — kiểm chứng 8/8 với GnuPG	Dữ liệu không bị khóa vào sản phẩm

Về hiệu năng, các số liệu tại Bảng 12 và Bảng 13 cho thấy chi phí tính toán của mã hóa **không phải là trở ngại sử dụng**: 15–36 ms cho một bức thư thông thường, dưới nửa giây cho tệp đính kèm 5 MB.

11.2. Hiệu quả kinh tế

Cần nói rõ ngay: **sáng kiến chưa được triển khai diện rộng, nên chưa có hiệu quả kinh tế đã thực hiện để báo cáo**. Phần dưới đây là *dự kiến*, nêu rõ căn cứ và điều kiện của từng khoản.

Chi phí trực tiếp bằng không. Giải pháp không phát sinh chi phí bản quyền phần mềm (giấy phép AGPL-3.0, sử dụng nội bộ phi thương mại), không phát sinh chi phí máy chủ, không phát sinh chi phí thiết bị. Toàn bộ công sức xây dựng là công sức của tác giả trong quá trình công tác.

Chi phí tránh được so với các phương án thay thế. Bảng dưới đây liệt kê khoản mục và *căn cứ*, chưa quy đổi thành tiền vì việc quy đổi đòi hỏi số lượng người dùng thực tế — hiện chưa có.

Bảng 16. Các khoản chi phí tránh được so với phương án thay thế

Phương án thay thế	Khoản chi phí phát sinh mà giải pháp này tránh được
Chuyển sang dịch vụ thư điện tử bảo mật	Phí thuê bao theo người dùng theo năm; chi phí di chuyển dữ liệu; chi phí đào tạo lại; rủi ro gián đoạn công tác
Triển khai hạ tầng S/MIME	Đầu tư hệ thống chứng thực số; chi phí cấp và gia hạn chứng thư cho từng người dùng; nhân sự vận hành
Mua giấy phép thương mại của sản phẩm gốc để dùng tài khoản Workspace	Phí giấy phép theo người dùng theo tháng
Đặt hàng phát triển phần mềm tương đương	Chi phí phát triển, kiểm thử, bản địa hóa và tài liệu hóa

Ghi chú để hoàn thiện khi triển khai: số người dùng dự kiến [...]; đơn giá tham chiếu của phương án thay thế được chọn để so sánh [...]; giá trị quy đổi [...].

Hiệu quả gián tiếp. Thời gian tiết kiệm được nhờ giao diện tiếng Việt (giảm thời gian đào tạo và giảm số lần thao tác sai), và chi phí tránh được từ việc phòng ngừa rò rỉ thông tin. Cả hai đều **chưa đo được** và cần được xác nhận qua triển khai thực tế; hồ sơ không quy đổi thành con số để tránh đưa ra ước lượng không có căn cứ.

11.3. Hiệu quả về quốc phòng — an ninh

Thu hẹp bề mặt rò rỉ thông tin. Với thư điện tử thông thường, nội dung tồn tại ở dạng rõ trên hạ tầng của nhà cung cấp trong suốt thời gian lưu trữ. Với Secure Mail, nội dung ở dạng bản mã, và khóa giải mã không tồn tại ở bất kỳ đâu ngoài máy trạm của người dùng. Đây là thay đổi về bản chất, không phải về mức độ.

Loại bỏ rò rỉ siêu dữ liệu quan hệ. Việc tắt toàn bộ tra cứu máy chủ khóa bên ngoài loại bỏ một kênh mà qua đó tập hợp quan hệ liên lạc của đơn vị có thể bị thu

thập ở nước ngoài. Với công tác bảo vệ nội bộ, thông tin "ai thường liên lạc với ai" có giá trị độc lập với nội dung liên lạc.

Giảm phụ thuộc vào nhà cung cấp nước ngoài. Sau khi gỡ bỏ hai kênh liên lạc ra bên thứ ba, khả năng đọc dữ liệu đã mã hóa của đơn vị không còn phụ thuộc vào bất kỳ dịch vụ nào ngoài hạ tầng thư mà đơn vị chủ động chọn. Kể cả khi mất kết nối Internet, thư đã tải về vẫn giải mã được bằng khóa lưu tại máy.

Nâng cao năng lực làm chủ công nghệ. Toàn bộ mã nguồn nằm trong tầm kiểm soát của đơn vị, đọc được, sửa được, biên dịch lại được từ mã nguồn. Đây là điều kiện cần để một sản phẩm an toàn thông tin được tin dùng: không có "hộp đen".

Đóng góp vào công tác đào tạo nhân lực an toàn thông tin. Đây là hiệu quả gián tiếp nhưng lâu dài. Người học được thực hành mật mã ứng dụng trên công cụ thật, bằng tiếng Việt, với hệ thuật ngữ thống nhất giữa bài giảng và phần mềm. Một bộ phận trong số họ sẽ là cán bộ bảo đảm an toàn thông tin của các đơn vị trong tương lai.

11.4. Hiệu quả xã hội

Đóng góp cho việc chuẩn hóa thuật ngữ mật mã tiếng Việt. Bộ thuật ngữ tại Bảng 5 được xây dựng có cân nhắc và đã được áp dụng nhất quán trên 586 chuỗi giao diện, kiểm tra bằng công cụ. Đây là tài sản dùng lại được cho giáo trình, bài giảng và các phần mềm khác.

Góp phần phổ cập mã hóa đầu cuối. Rào cản ngôn ngữ là một trong những nguyên nhân khiến mã hóa thư điện tử không phổ cập ở Việt Nam ngoài giới chuyên môn. Hạ rào cản đó có tác dụng vượt ra ngoài phạm vi một đơn vị.

Chia sẻ được. Toàn bộ mã nguồn ở giấy phép AGPL-3.0, có thể chia sẻ cho các đơn vị khác cùng dùng và cùng cải tiến.

12. Phạm vi áp dụng và giới hạn — trình bày trung thực

Mục này được viết ra để hồ sơ không đưa ra bất kỳ khẳng định nào vượt quá cơ sở thực tế. Tác giả cho rằng chính sự chính xác này làm hồ sơ đáng tin cậy hơn.

12.1. Phân biệt ba mức khẳng định

Cần phân biệt rõ ba điều thường bị đồng nhất:

- 19. **Năng lực kỹ thuật của giải pháp** — điều mà sáng kiến đã chứng minh được bằng đo đạc và kiểm thử.
- 20. **Tiềm năng ứng dụng** — điều mà giải pháp có thể làm được nếu được đầu tư và phê duyệt tiếp.
- 21. **Tư cách pháp lý để sử dụng cho một loại thông tin cụ thể** — điều **không do năng lực kỹ thuật quyết định**, mà do quy định pháp luật và cơ quan có thẩm quyền quyết định.

Hồ sơ này khẳng định mức 1, đề xuất mức 2, và **không đưa ra bất kỳ khẳng định nào ở mức 3**.

Phạm vi dữ liệu phù hợp và ranh giới pháp lý

Phù hợp về kỹ thuật và pháp lý Tài liệu phục vụ giảng dạy, đề cương, đề thi chưa công bố Kết quả học tập và dữ liệu cá nhân của người học Tài liệu nghiên cứu, bản thảo chưa công bố Trao đổi nghiệp vụ nội bộ không thuộc danh mục bí mật nhà nước Dữ liệu cần bảo vệ khi truyền qua hạ tầng công cộng	Cần đánh giá và phê duyệt riêng Thông tin nội bộ nhạy cảm chưa được phân loại Dữ liệu có yêu cầu lưu vết và kiểm toán tập trung Trường hợp cần khôi phục khóa tập trung (key escrow) Cần có quy chế sử dụng của đơn vị trước khi triển khai	Không áp dụng khi chưa có cơ sở pháp lý Thông tin thuộc danh mục bí mật nhà nước Việc truyền, nhận thông tin bí mật nhà nước qua mạng phải sử dụng sản phẩm mật mã và tuân thủ quy định về cơ yếu — Luật Bảo vệ bí mật nhà nước năm 2018 và Nghị định số 26/2020/NĐ-CP. Secure Mail chưa được kiểm định và chưa được cấp phép cho mục đích này.
---	--	---

Hồ sơ này khẳng định năng lực kỹ thuật của giải pháp, không khẳng định tư cách pháp lý để bảo vệ bí mật nhà nước. Ranh giới này được nêu ngay từ đầu, không phải là hạn chế được phát hiện về sau.

Hình 12. Phạm vi dữ liệu phù hợp và ranh giới pháp lý

12.2. Về thông tin thuộc danh mục bí mật nhà nước

Nêu rõ để không có hiểu nhầm:

Secure Mail chưa được kiểm định, chưa được cấp phép và không được đề xuất sử dụng để truyền, nhận thông tin thuộc danh mục bí mật nhà nước. Việc chuyển, nhận tài liệu, vật chứa bí mật nhà nước qua mạng Internet, mạng máy tính và mạng viễn thông phải được thực hiện theo quy định của pháp luật về cơ yếu, và phải sử dụng sản phẩm mật mã do cơ quan có thẩm quyền cung cấp (Luật Bảo vệ bí mật nhà nước năm 2018; Nghị định số 26/2020/NĐ-CP ngày 28/02/2020). Việc một giải pháp sử dụng thuật toán mạnh và được kiểm thử kỹ **không tự nó tạo ra tư cách pháp lý** cho mục đích trên. Tư cách đó chỉ có được qua kiểm định và cấp phép của cơ quan có thẩm quyền.

Phạm vi áp dụng được đề xuất giới hạn ở: **thông tin cần được bảo vệ nhưng không thuộc danh mục bí mật nhà nước** — tài liệu giảng dạy, đề thi chưa công bố, kết quả học tập, dữ liệu cá nhân của người học, tài liệu nghiên cứu chưa công bố, trao đổi nghiệp vụ nội bộ theo quy chế của đơn vị.

12.3. Những giới hạn kỹ thuật khác cần biết

Liệt kê đầy đủ, không né tránh:

- **Siêu dữ liệu không được bảo vệ.** Người gửi, người nhận, thời gian, kích thước và **tiêu đề thư** vẫn hiển thị với nhà cung cấp. Hệ quả thực tế: người dùng phải được hướng dẫn **không đặt nội dung nhạy cảm vào tiêu đề thư**. Điều này đã được đưa vào tài liệu hướng dẫn người dùng.
- **An toàn phụ thuộc vào máy trạm.** Nếu máy trạm bị nhiễm mã độc có khả năng ghi phím hoặc đọc bộ nhớ, mã hóa đầu cuối không bảo vệ được. Đây là giới hạn nền tảng của mọi giải pháp mã hóa phía người dùng.
- **Mất khóa riêng tư mà không có bản sao lưu là mất vĩnh viễn thư cũ.** Không có cơ chế khôi phục tập trung — đây là hệ quả tất yếu của việc quản trị viên không giữ khóa riêng tư. Sản phẩm bù lại bằng chức năng sao lưu và phiếu khôi phục, kèm cảnh báo bằng tiếng Việt ngay trong giao diện. Nếu đơn vị có yêu cầu khôi phục tập trung, cần thiết kế bổ sung và phải cân nhắc kỹ vì nó thay đổi mô hình an toàn.

- **Chưa qua đánh giá an toàn độc lập.** Sản phẩm chưa được kiểm định bởi một tổ chức đánh giá độc lập. Toàn bộ kiểm thử trong hồ sơ là do tác giả thực hiện, và chính vì vậy tác giả cung cấp kèm bộ kịch bản để bên thứ ba chạy lại.
- **Chưa triển khai diện rộng.** Chưa có số liệu người dùng thực tế, chưa có ghi nhận hiệu quả từ đơn vị sử dụng. Các mục này trong hồ sơ được để trống có đánh dấu.
- **Phụ thuộc vào giao diện web của Gmail.** Phần chèn giao diện bám vào cấu trúc trang Gmail; khi Google thay đổi lớn giao diện, phần này cần được cập nhật. Phần lỗi mật mã không bị ảnh hưởng.
- **Bản di động chưa hoàn chỉnh.** Nền tảng đã xong và kiểm chứng được; giao diện người dùng chưa xong.

13. Mức độ triển khai và hướng phát triển

13.1. Mức độ hoàn thành hiện tại

Bảng 17. Trạng thái các hạng mục

Hạng mục	Trạng thái
Tiện ích máy tính: mã hóa, giải mã, ký, xác minh, quản lý khóa	Hoàn thành, đã kiểm thử
Tích hợp Gmail (giao diện web và Gmail API)	Hoàn thành, đã kiểm thử
Bản địa hóa tiếng Việt và bộ chọn ngôn ngữ	Hoàn thành — 586/586, 0 lỗi chặn
Cải tạo mô hình tin cậy và cắt phụ thuộc bên thứ ba	Hoàn thành, kiểm chứng 4/4
Xác thực OAuth với định danh cố định và PKCE	Hoàn thành
Bộ công cụ kiểm chứng	Hoàn thành — 5 kịch bản
Tài liệu vận hành tiếng Việt	Hoàn thành — 9 tài liệu
Phiên bản di động: nền tảng kỹ thuật	Hoàn thành — 68/68 phép thử đạt
Phiên bản di động: giao diện người dùng	Đang thực hiện
Phiên bản di động: tích hợp Gmail	Chưa bắt đầu — giai đoạn 2
Phiên bản iOS	Chưa bắt đầu — giai đoạn 3
Triển khai thí điểm và đánh giá thực tế	Chưa thực hiện

13.2. Kế hoạch phát triển

Giai đoạn 1 — Triển khai thí điểm và hoàn thiện dựa trên phản hồi. Đây là việc cần làm ngay và là việc quan trọng nhất, vì nó bổ sung phần còn thiếu quyết định của hồ sơ: số liệu sử dụng thực tế. Nội dung: triển khai cho một nhóm người dùng, tổ

chức tập huấn, thiết lập quy trình quản lý khóa công khai của đơn vị, ghi nhận vướng mắc, đo thời gian đào tạo thực tế và tỷ lệ thao tác thành công. [Quy mô và thời gian dự kiến bổ sung sau khi được phê duyệt]

Giai đoạn 2 — Hoàn thiện ứng dụng Android. Hoàn thiện giao diện người dùng trên nền cầu RPC và lỗi mật mã đã kiểm chứng; bổ sung tích hợp Gmail trên di động với luồng OAuth riêng cho ứng dụng Android dùng PKCE không kèm bí mật client.

Giai đoạn 3 — Mở rộng. Phiên bản iOS (kiến trúc đã được thiết kế để không phải viết lại); hỗ trợ thêm nhà cung cấp thư điện tử ngoài Gmail; nghiên cứu khả năng vận hành một máy chủ khóa nội bộ hoặc Web Key Directory trên tên miền của đơn vị, để tự động hóa việc phân phối khóa công khai mà vẫn giữ nguyên nguyên tắc khép kín.

Giai đoạn 4 — Nếu có nhu cầu và được phê duyệt. Đưa sản phẩm ra đánh giá an toàn độc lập; nghiên cứu khả năng tích hợp với sản phẩm mật mã của cơ quan có thẩm quyền để mở rộng phạm vi dữ liệu áp dụng.

13.3. Bảo đảm duy trì khi tác giả không còn trực tiếp phụ trách

Một sản phẩm chỉ một người hiểu là một rủi ro, không phải một thành tựu. Đây là lý do phần lớn công sức của sáng kiến được đầu tư vào những thứ bàn giao được:

- **Mã nguồn đầy đủ trong hệ thống quản lý phiên bản**, có lịch sử thay đổi, mỗi thay đổi kèm giải thích lý do — không chỉ mô tả cái gì đã đổi mà cả vì sao.
- **Quy trình dựng lại được ghi thành lệnh cụ thể** (Phụ lục kỹ thuật, mục D): bất kỳ ai có máy và Node.js đều biên dịch lại được bản phát hành từ mã nguồn.
- **Bộ kịch bản kiểm chứng** cho phép người tiếp nhận tự xác nhận sản phẩm còn đúng sau mỗi lần sửa, mà không cần hiểu toàn bộ mã nguồn.
- **Chín tài liệu vận hành bằng tiếng Việt**: cài đặt, hướng dẫn người dùng, quy trình quản lý khóa công khai, quy trình phát hành, danh mục kiểm tra an toàn, danh mục kiểm thử.
- **Lỗi mật mã không bị sửa**, nên người tiếp nhận chỉ cần hiểu phần cải tạo, không phải hiểu toàn bộ một thư viện mật mã.

Điểm cuối cùng đáng nhấn mạnh: kỷ luật "không sửa cái không cần sửa" ở mục 6.1 không chỉ là quyết định về an toàn, mà còn là quyết định về khả năng bàn giao.

13.4. Khả năng nhân rộng

Sáng kiến được thiết kế để nhân rộng được:

- **Không phụ thuộc hạ tầng riêng** — bất kỳ đơn vị nào có máy tính và trình duyệt đều dùng được.
- **Tài liệu đầy đủ bằng tiếng Việt** — hướng dẫn cài đặt, hướng dẫn người dùng, quy trình quản trị khóa, quy trình phát hành, danh mục kiểm tra an toàn.
- **Quy trình xây dựng lặp lại được** — mọi bản phát hành đều biên dịch lại được từ mã nguồn và kiểm chứng lại được bằng bộ kịch bản kèm theo.
- **Bộ thuật ngữ và bản dịch dùng lại được** cho các phần mềm an toàn thông tin khác.

14. Trả lời trước những câu hỏi phản biện

Mục này tập hợp những câu hỏi khó nhất mà tác giả tự đặt ra khi rà soát hồ sơ, kèm câu trả lời và chỉ dẫn tới bằng chứng. Đưa chúng vào hồ sơ là có chủ đích: một sáng kiến chịu được phản biện thì nên trình bày phản biện đó ra, thay vì chờ bị hỏi.

Câu hỏi 1. Đây có phải chỉ là dịch giao diện một phần mềm nguồn mở sang tiếng Việt?

Không. Bản dịch là một trong năm điểm mới, và bản thân nó đòi hỏi phải sửa kiến trúc lớp đa ngữ trước thì mới thực hiện được — bản gốc khóa cứng ngôn ngữ theo trình duyệt, nên chỉ thêm một thư mục ngôn ngữ là vô tác dụng với người dùng dùng Chrome tiếng Anh.

Bốn điểm còn lại là công việc kỹ thuật trên mã nguồn, ảnh hưởng trực tiếp tới thuộc tính an toàn, và không thể thực hiện bằng cách dịch: chuyển mô hình tin cậy, gỡ bỏ hai kênh liên lạc ra bên thứ ba, làm luồng xác thực an toàn và triển khai được, xây dựng kiến trúc di động.

Phép thử đơn giản nhất cho câu hỏi này: **nếu chỉ dịch mà không làm gì khác, sản phẩm có triển khai được không?** Không. Tài khoản Google Workspace của cơ quan sẽ bị chặn bởi cơ chế kiểm tra giấy phép; luồng xác thực sẽ thất bại với lỗi `redirect_uri_mismatch` vì mã định danh tiện ích thay đổi theo từng máy; và mỗi lần soạn thư cho một địa chỉ mới sẽ phát sinh một truy vấn ra máy chủ khóa ở nước ngoài. *Bằng chứng: Bảng 2, mục 6.5, mục 6.6.*

Câu hỏi 2. Bằng chứng do chính tác giả tạo ra và tự kiểm. Ai bảo đảm?

Đây là câu hỏi đúng, và hồ sơ được thiết kế để trả lời được nó theo ba cách:

- **Phép thử liên thông dùng một trọng tài độc lập.** GnuPG không do tác giả viết, không liên quan gì tới dự án này, và được phát triển bởi một tổ chức khác. Việc GnuPG đọc đúng bản mã và xác minh đúng chữ ký là bằng chứng do bên ngoài đưa ra. *Bảng 11.*
- **Bộ kiểm thử đơn vị 449 phép thử là kế thừa,** không do tác giả viết. Chính vì thế nó mới chứng minh được rằng việc cải tạo không phá vỡ chức năng sẵn có. *Bảng 10.*

- **Mọi kịch bản đều đi kèm hồ sơ và chạy lại được.** Hội đồng không cần tin kết quả trong hồ sơ; Phụ lục kỹ thuật mục D ghi lệnh chính xác để chạy lại từng phép trên chính gói phát hành.

Câu hỏi 3. Chi phí bằng không thì giá trị nằm ở đâu?

Chi phí bằng không là **kết quả của thiết kế**, không phải dấu hiệu thiếu giá trị: giải pháp cố tình được xây dựng để không cần máy chủ, không cần chứng thư số, không cần đổi nhà cung cấp thư — vì mỗi thứ đó đều là một rào cản triển khai.

Giá trị nằm ở chỗ khác: thông tin đang được gửi ở dạng rõ nay được bảo vệ; quan hệ liên lạc của đơn vị không còn bị lộ ra máy chủ nước ngoài; và người học có công cụ thực hành bằng tiếng Việt. Hồ sơ **không quy đổi những giá trị này thành tiền** vì chưa có căn cứ, và nêu rõ điều đó thay vì ước lượng. *Mục 11.2.*

Câu hỏi 4. Đã có sản phẩm mật mã của cơ quan có thẩm quyền, sao còn cần cái này?

Hai thứ phục vụ hai lớp thông tin khác nhau. Với thông tin thuộc danh mục bí mật nhà nước, sản phẩm mật mã của cơ quan có thẩm quyền là bắt buộc và Secure Mail không thay thế. Với lớp thông tin còn lại — chiếm phần lớn khối lượng trao đổi hằng ngày — hiện đang được gửi bằng thư điện tử thông thường, tức là không được bảo vệ gì. Sáng kiến lấp đúng khoảng trống đó. *Mục 3.5, mục 12.*

Câu hỏi 5. Dùng phần mềm nguồn mở nước ngoài làm nền có an toàn không?

Lựa chọn thực tế là giữa phần mềm **đọc được mã nguồn** và phần mềm **hộp đen**. Toàn bộ khả năng kiểm chứng của hồ sơ này bắt nguồn từ việc mã nguồn mở ra để đọc — kể cả việc phát hiện ra rằng bản gốc có thư viện đo lường từ xa và cơ chế gọi về máy chủ cấp phép. Rủi ro được kiểm soát bằng bốn biện pháp: đóng băng phiên bản không tự cập nhật, khóa chặt chuỗi cung ứng phụ thuộc, rà soát và cắt bỏ, kiểm chứng bằng bên thứ ba độc lập. *Mục 6.9.*

Câu hỏi 6. Nếu Google thay đổi giao diện Gmail thì sản phẩm có hỏng không?

Phần chèn giao diện có thể cần cập nhật; **phần lõi mật mã không bị ảnh hưởng**, vì hai phần được tách rời hoàn toàn (mục 6.2). Trong trường hợp xấu nhất, người dùng vẫn mã hóa và giải mã được qua trang tùy chọn của tiện ích rồi dán kết quả vào Gmail

— thư đã mã hóa không bao giờ trở nên không đọc được. Đây là hệ quả trực tiếp của việc bản mã là OpenPGP chuẩn chứ không phải định dạng riêng.

Câu hỏi 7. Mất khóa riêng tư thì mất luôn thư cũ. Đó không phải rủi ro cho đơn vị sao?

Đúng, và đây là hệ quả tất yếu của việc quản trị viên **không** giữ khóa riêng tư. Đó là một đánh đổi có ý thức: nếu quản trị viên giữ khóa riêng tư thì mô hình mã hóa đầu cuối sụp đổ, vì khi đó tồn tại một điểm đọc được mọi thư.

Sản phẩm bù lại bằng chức năng sao lưu khóa, phiếu khôi phục, và cảnh báo bằng tiếng Việt ngay trong giao diện tại thời điểm người dùng vừa tạo khóa — chứ không để trong tài liệu mà không ai đọc. Nếu đơn vị có yêu cầu khôi phục khóa tập trung, việc đó cần thiết kế bổ sung và phải được cân nhắc kỹ vì nó thay đổi mô hình an toàn. *Mục 6.4.2, mục 12.3.*

Câu hỏi 8. Sản phẩm chưa qua kiểm định độc lập. Vậy có dùng được không?

Có, trong phạm vi được đề xuất tại mục 12: thông tin cần bảo vệ nhưng không thuộc danh mục bí mật nhà nước. Với thông tin thuộc danh mục bí mật nhà nước thì không, và hồ sơ nêu rõ điều đó ngay từ đầu.

Tác giả không tuyên bố sản phẩm đã được đánh giá độc lập. Chính vì vậy hồ sơ cung cấp kèm bộ kịch bản để bên thứ ba chạy lại — đó là điều tác giả làm được trong khả năng của mình để bù cho việc chưa có kiểm định.

Câu hỏi 9. Tác giả chuyển công tác thì ai duy trì?

Mã nguồn, quy trình dựng lại thành lệnh cụ thể, bộ kịch bản kiểm chứng và chín tài liệu vận hành bằng tiếng Việt đều đã sẵn sàng bàn giao. Lỗi mật mã không bị sửa nên người tiếp nhận chỉ cần hiểu phần cải tạo. *Mục 13.3.*

Câu hỏi 10. Đối với quân đội và công tác an toàn thông tin, giá trị cụ thể là gì?

Ba giá trị, xếp theo mức độ chắc chắn:

22. **Chắc chắn ngay:** nội dung thư trong phạm vi triển khai không còn tồn tại ở dạng rõ trên hạ tầng của nhà cung cấp; quan hệ liên lạc của đơn vị không còn bị lộ qua tra cứu máy chủ khóa ở nước ngoài; sản phẩm không phụ thuộc vào dịch vụ thương mại của bên thứ ba. Cả ba đều kiểm chứng được bằng lệnh.

23. **Chắc chắn về khả năng, phụ thuộc vào triển khai:** năng lực làm chủ công nghệ — toàn bộ mã nguồn đọc được, sửa được, biên dịch lại được, không có hộp đen.
24. **Dài hạn:** nâng chất lượng đào tạo nhân lực an toàn thông tin, nhờ một học cụ thực tế bằng tiếng Việt với hệ thuật ngữ thống nhất giữa bài giảng và phần mềm.

KẾT LUẬN

Sáng kiến giải quyết một vấn đề có thật trong công tác giảng dạy và bảo đảm an toàn thông tin của đơn vị: nhu cầu bảo vệ nội dung trao đổi qua thư điện tử và nhu cầu có một công cụ thực hành mật mã ứng dụng bằng tiếng Việt.

Giá trị của giải pháp không nằm ở một thuật toán mới, mà nằm ở công việc kỹ thuật biến những cơ chế mật mã đã được kiểm chứng thành một sản phẩm **triển khai được trong điều kiện thực tế của đơn vị**: bằng tiếng Việt hoàn chỉnh, với mô hình tin cậy do đơn vị kiểm soát, không kèm phụ thuộc vào bên thứ ba, và — điểm mà tác giả coi trọng nhất — **mọi khẳng định về an toàn đều có một lệnh để người khác kiểm tra lại**.

Toàn bộ số liệu trong hồ sơ đều đo được và tái lập được. Những gì chưa có cơ sở thực tế đều được ghi rõ là chưa có, thay vì được ước lượng thành con số.

XÁC NHẬN CỦA ĐƠN VỊ

TÁC GIẢ SÁNG KIẾN

[Ký, ghi rõ họ tên, đóng dấu]

[Họ và tên tác giả]